성평등가족부 사이버보안 업무규정

(구 성평등가족부 정보보안 업무규정)

제 정 2001.04.28. 여성부훈령 제14호
전부개정 2009.08.11. 여성부훈령 제26호
개 정 2010.09.03. 여성가족부훈령 제21호
전부개정 2011.05.16. 여성가족부훈령 제29호
일부개정 2014.09.01. 여성가족부훈령 제74호
전부개정 2019.08.23. 여성가족부훈령 제134호
일부개정 2020.11.25. 여성가족부훈령 제151호
일부개정 2022.10.04. 여성가족부훈령 제177호
일부개정 2023.04.14. 여성가족부훈령 제180호
일부개정 2026.08.26. 성평등가족부훈령 제23호

제1장 총칙

제1조(목적) 이 규정은 「국가 사이버보안 기본지침」에 따라 성평등가족부의 사이버보안 업무 수행에 필요한 사항을 규정함을 목적으로 한다.

제2조(정의) 이 규정에서 사용하는 용어의 정의는 다음과 같다.

1. "사이버보안"이라 함은 각 기관의 기능 유지를 주 목적으로 정보통신망 및 정보시스템을 통해 수집, 가공, 저장, 검색, 송·수신되는 정보의 유출, 위·변조, 훼손 등을 방지하기 위하여 관리적·물리적·기술적 수단을 강구하는 일체의 행위를 말한다.

가. <삭제>

나. <삭제>

다. <삭제>

라. <삭제>

마. <삭제>

2. "사이버보안담당관"이라 함은 각 기관의 사이버보안업무를 총괄하기 위하여 각 기관의 장이 임명한 사람을 말한다.

3. <삭제>

4. "정보통신망"이라 함은「사이버안보 업무규정」제2조제1호에 따른 정보통신망을 말한다.

5. "기밀등급(Classified) 도메인(Domain)"이란 기밀등급 이하의 정보시스템·단말기가 위치하거나 기밀등급 이하의 업무정보를 처리하기 위한 목적으로 각급기관이 구축·운영하는 정보통신망 영역을 말한다.

5의2. "민감등급(Sensitive) 도메인 (Domain)"이란 민감등급 이하의 정보시스템·단말기가 위치하거나 민감등급 이하의 업무정보를 처리하기 위한 목적으로 각급기관이 구축·운영하는 정보통신망 영역이거나, 또는 각급기관이 이용하는 외부 클라우드컴퓨팅 영역을 말한다.

6. "공개등급(Open) 도메인"이란 공개등급 정보시스템·단말기가 위치하거나 공개등급 업무정보를 처리하기 위한 목적으로 각급기관이 구축·운영하는 정보통신망 영역이거나, 또는 각급기관이 이용하는 외부 정보통신망·클라우드컴퓨팅 영역을 말한다.("상용 인터넷망"을 포함한다.)

7. <삭제>

8. "정보시스템"이라 함은 각급기관이 구축·운영하는 「전자정부법」제2조제13호에 따른 정보시스템을 말하며, 다음 각 목의 구분에 따른다.

가. 기밀등급(Classified) 정보시스템 : 기밀등급 이하의 업무정보를 처리

나. 민감등급(Sensitive) 정보시스템 : 민감등급 이하의 업무정보를 처리

다. 공개등급(Open) 정보시스템 : 공개등급 업무정보만을 처리

9. "휴대용 저장매체"라 함은 CD·외장형 하드디스크·USB메모리 등 정보를 저장할 수 있는 것으로 PC·서버 등의 정보시스템과 분리할 수 있는 기억장치를 말한다.

10. "업무정보"라 함은 다음 각 목의 어느 하나에 해당하는 것을 말한다.

가.「전자정부법」 제2조제6호에 따른 행정정보 및 같은 법 제2조제7호에 따른 전자문서

나.「공공기록물 관리에 관한 법률 시행령」 제2조제2호에 따른 전자기록물

다. 기타, 다른 법령에 의하여 공무원등이 직무상 작성·취득하였거나 보유·관리하는 자료로서 전자적으로 처리되어 부호·문자·음성·음향·영상 등으로 표현된 것

11. "기밀등급(Classified) 업무정보"라 함은 업무정보중에서 다음 각 목의 어느 하나에 해당하는 것을 말한다.

가. 「보안업무규정」 제4조에 따라 분류된 비밀(이하 "비밀"이라 한다)

나. 「보안업무규정 시행규칙」 제16조제3항에 따라 분류된 대외비(이하 "대외비"라 한다)

다. 가목 및 나목 외에 「공공기관의 정보공개에 관한 법률」 제9조제1항제1호부터 제4호까지에 따른 비공개 대상 정보

12. <삭제>

13. "민감등급(Sensitive) 업무정보"라 함은 업무정보 중에서 다음 각 목의 어느 하나에 해당하는 정보를 말한다.

가.「공공기관의 정보공개에 관한 법률」 제9조제1항제5호부터 제8호까지에 따른 비공개 대상 정보

나. 국회 소속 공무원(「국회의원수당 등에 관한 법률」제9조에 따른 보좌직원을 포함한다) 또는「지방자치법」제30조에 따른 지방의회 소속 공무원의 직무상 요구에 따라 작성 또는 취득한 자료

다. 가목에 따른 비공개 대상 정보의 주요 내용이 기술된 문장 또는 문구

14. "공개등급(Open) 업무정보"라 함은 다음 각 목의 어느 하나에 해당하는 정보를 말한다.

가. 업무정보 중에서 기밀등급 및 민감등급 업무정보를 제외한 모든 정보(「공공데이터의 제공 및 이용 활성화에 관한 법률」 제19조에 따라 공표된 공공데이터를 포함한다)

나. 관련 법령 등에서 규정하는 요건을 조치한 행정・민감정보

다. 기간의 경과 등으로 비공개 필요성이 소멸되어 공개한 정보

15. "정보통신실"이라 함은 서버・스위치・라우터・교환기 등 전산 및 통신장비 등이 설치・운용되는 장소 또는 전산실・통신실・데이터센터 등을 말한다.

16. "정보보호시스템"이라 함은「지능정보화 기본법」제2조제15호에 따른 정보보호시스템을 말한다.

17. "국가용 보안요구사항"이라 함은「사이버안보 업무규정」제9조제2항에 따른 정보보호시스템등의 도입·운영에 관한 보안대책의 일환으로 국가정보원장이 정하는 보안 관련 요구사항을 말한다.

18. "국가용 보호프로파일(Protect Profile)"라 함은「지능정보화 기본법」제58조제1항 및 같은 법 시행령 제51조에 따라 과학기술정보통신부장관이 고시한「정보보호시스템 평가·인증 지침」에 따른 보호프로파일 중에서 국가정보원장이 국가용 보안요구사항을 만족한다고 인정한 것을 말한다.

19. <삭제>

20. "국가보안기술연구소"라 함은「과학기술분야 정부출연연구기관 등의 설립·운영 및 육성에 관한 법률」제8조제1항에 따라 설립된 한국전자통신연구원 부설 국가보안기술연구소를 말한다.

21. "안전성 검증필 제품"이라 함은 국가정보원장이 국가용 보안요구사항 만족여부 등 안전성을 확인하여 제19조에 따른 안전성 검증필 제품 목록에 등재한 정보통신제품을 말한다.

22. "보안적합성 검증"이라 함은 제18조제1항제3호의 보안기능이 있는 정보통신제품에 대하여 실제 적용·운용 이전에 시험 등의 방법으로 안전성을 검증하는 활동을 말한다.

23. "공무원등"이라 함은 각급기관에 근무중인 다음 각 목의 어느 하

나에 해당하는 사람을 말한다.

가.「국가공무원법」제2조에 따른 국가공무원

나.「지방공무원법」제2조에 따른 지방공무원

다.「교육공무원법」제2조에 따른 교육공무원

라. 공공기관 임직원

마. 공무직 근로자 및 기간제 근로자

바. 「병역법」 제2조에 따른 상근예비역, 승선근무예비역, 사회복무요원, 공중보건의사, 공익법무관, 병역판정검사전담의사, 공중방역수의사 및 전문연구요원

24. "개별사용자"라 함은 각급기관의 장으로부터 정보통신망 또는 정보시스템에 대한 접근 또는 사용 허가를 받은 공무원등과 각급기관의 장과 계약에 의하여 정보통신망 또는 정보시스템에 대한 접근 또는 사용 허가를 받은 사람을 말한다.

25. "전자파 보안"이라 함은 정보통신시설 및 기기 등을 대상으로 전자파에 의한 정보유출을 방지하고 파괴·오작동 유발 등의 위협으로부터 정보를 보호하는 일체의 행위를 말한다.

26. "대도청 측정(TSCM)"이라 함은 유·무선 도청탐지장비 등을 사용하여 은닉된 도청장치를 색출하거나 누설전자파(정보통신기기로부터 자유공간 또는 전도성 경로를 통해 비(非)의도적으로 누출되는 정보를 포함한 전자파) 등 각종 도청 위해(危害)요소를 제거하는 제반활동을 말한다.

27. "고출력 전자파(EMP)"라 함은 지상 30km 이상에서 핵 폭발에 의해 생성되는 고고도(高高度) 핵 전자파와 의도적으로 정보기기 등을 손상시키거나 오동작을 유발할 수 있는 고출력 비핵 전자파를 말한다.

28. "사이버공격·위협"이라 함은 「사이버안보 업무규정」 제2조제2호에 따른 행위를 말한다.

29. "보안관제"라 함은 사이버공격·위협을 실시간으로 즉시 탐지 및 분석, 대응하는 일련의 활동을 말한다.

30. "보안관제센터"라 함은 일정한 수준의 시설 및 장비와 이를 운영하기 위한 전문 또는 전담인력을 갖추고 보안관제업무를 수행하는 조직을 말한다.

31. <삭제>

32. "부문보안관제센터"라 함은 「사이버안보 업무규정」 제14조제2항에 따라 설치·운영되는 보안관제센터 중 중앙행정기관의 장이 해당 기관 및 관할 하급기관의 정보통신망을 대상으로 운영하는 센터를 말한다.

33. "취약점"이라 함은 사이버공격·위협에 악용되어 관리자가 설정한 접근 권한外 정보를 열람·취득하게 하거나 보안기능을 회피 가능하게 하는 정보통신망·정보시스템의 결함을 말한다.

34. "각급기관"이라 함은 헌법과 법률에 의하여 설치된 국가기관·지방자치단체·교육청 및 그 소속기관, 공공기관, 국·공립학교(「초·중등교육법」 및 「고등교육법」에 따른 국·공립학교를 말한다. 이하 같다) 및 군(軍)기관을 말한다.

35. "각 기관"이라 함은 성평등가족부와 그 산하 공공기관(이하 "산하기관"이라한다)을 말한다.

36. "정보화사업담당관" 이라 함은 정보화사업(개발・구축・운영・유지보수)을 발주하는 부서의 장을 말한다.

37. "사이버보안 실태 평가"라 함은 「사이버안보 업무규정」 제13조 및 「전자정부법」 제56조 등에 따라 각급기관의 사이버보안 정책에 대한 이행여부를 확인하기 위하여 실시하는 평가를 말한다.

38. "암호모듈"이라 함은 암호알고리즘을 소프트웨어, 하드웨어, 펌웨어 또는 이를 조합한 형태로 구현한 것으로서 정보보호시스템, 암호장치, 보안기능이 있는 정보통신기기에 적용되는 장치나 수단을 말한다.

39. "검증필 암호모듈"이라 함은 「사이버안보 업무규정」 제9조제2항 및 제3항, 「전자정부법 시행령」 제69조와 「암호모듈 시험 및 검증지침」(국가정보원 지침)에 따라 국가정보원장이 안전성을 확인하여 제22조에 따른 목록에 등재한 암호모듈을 말한다.

40. "안보위해(危害) 공격"이라 함은 사이버공격・위협 중에서 다음 각 목의 어느 하나에 해당하는 행위 또는 활동을 말한다.

가. 국제 및 국가배후 해킹조직의 활동 등 사이버안보 위협 행위

나. 국가안보와 국익에 반하는 북한, 외국 및 외국인・외국단체・초국가행위자 또는 이와 연계된 내국인의 활동

다. 「산업기술의 유출방지 및 보호에 관한 법률」제2조에 따른 국가핵심기술 이거나 국가연구개발사업으로 개발한 산업기술 또는 「방위산업기술 보호법」제2조제1호에 따른 방위산업기술을 부

정한 방법으로 취득하는 행위

라. 「북한이탈주민의 보호 및 정착지원에 관한 법률 시행령」 제42조의2에 따른 보호대상자의 개인정보 유출 또는 신변을 위해(危害)할 우려가 있는 해킹

마. 「국민보호와 공공안전을 위한 테러방지법」 제2조제1호에 따른 테러 행위

바. 국제범죄조직에 의한 사이버공격·위협

사. 「형법」 중 내란(內亂)의 죄, 외환(外患)의 죄, 「군형법」 중 반란의 죄, 암호 부정사용의 죄, 「군사기밀 보호법」 에 규정된 죄, 「국가보안법」 에 규정된 죄에 해당되는 행위

아. 국가기밀에 속하는 문서·자재·시설 및 지역에 관한 정보를 유출하거나 그 운영을 방해하는 행위

자. 「전자정부법」 제56조제3항에 따른 보안조치 대상 정보통신망에서 전자문서에 대한 위조·변조·훼손·절취하여 국가의 독립, 영토의 보전, 헌법과 법률의 기능, 헌법에 의하여 설치된 국가기관의 유지에 위해를 초래하는 행위

차. 「정보통신기반 보호법」 제3조에 따라 공공분야 실무위원회가 담당하는 주요정보통신기반시설 또는 같은 법 제7조제2항 각 호에 따른 주요정보통신기반시설에 대한 같은 법 제12조에 규정된 침해행위

카. 「국가자원안보 특별법」 제20조제2항에 따른 공급기반시설 대상 사이버보안 위협

41. "클라우드컴퓨팅(Cloud Computing)"이라 함은 직접·공유된 정보통신기기, 정보통신설비, 소프트웨어 등 정보통신자원을 이용자의 요구나 수요변화에 따른 정보통신망을 통하여 신축적으로 이용할 수 있도록 하는 정보처리체계를 말한다.

42. <삭제>

43. "인공지능(Artificial Intelligence)"이란「인공지능 발전과 신뢰기반 조성 등에 관한 기본법」제2조제1호에 따른 인공지능을 말한다.

44. "인공지능시스템"이라 함은「인공지능 발전과 신뢰 기반 조성 등에 관한 기본법」제2조제2호에 따른 인공지능시스템을 말한다.

제3조(적용범위) 각 기관의 사이버보안업무수행에 관한 사항은 다른 법령에 특별한 규정이 있는 경우를 제외하고는 이 규정이 정한 바에 따른다.

제4조(책무) ① 각 기관의 장은 국가안보 및 국익과 관련된 정보(업무자료를 포함한다. 이하 같다)와 정보통신망을 보호하기 위하여 보안대책을 수립·시행하여야 하며 사이버보안에 대한 책임을 진다.

② 각 기관의 장은 소속 직원에 대한 근무성적 또는 성과 평가를 실시할 경우 이 규정의 준수여부 등을 반영할 수 있다.

제5조(사이버보안담당관 운영) ① 각 기관의 장은 사이버보안업무를 효율적이고 체계적으로 수행하기 위하여 사이버보안 전문지식을 보유한 적정인력을 확보하여 사이버보안 전담조직을 구성·운영하여야 한다.

② 다음 각 호의 직원은 그 직위에 임명과 동시에 해당 기관의 사이버보안담당관에 임명된 것으로 본다.

1. 본부 : 정보통계담당관

2. 산하기관 : 사이버보안업무담당 부서의 장

③ 사이버보안담당관의 기본활동은 다음 각 호와 같다.

1. 사이버보안 정책·계획의 수립·시행 및 사이버보안내규 제·개정

2. 사이버보안 전담조직 관리, 전문인력 및 관련예산 확보

3. 정보화사업 보안성 검토 및 보안적합성 검증 총괄

4. 정보통신실, 정보통신망 현황자료 등에 관한 보안관리 총괄

5. 사이버공격 위협·대응훈련 및 사이버보안 실태 평가 총괄

6. 보안관제, 사고대응 및 정보협력 업무 총괄

7. 사이버보안교육 총괄 및 '사이버보안진단의 날' 계획 수립·시행

8. 해당 기관 및 관할 산하기관에 대한 사이버보안감사

9. 산하기관 사이버보안업무 감독

10. 부서 분임사이버보안담당관 업무 감독

11. 그 밖에 사이버보안과 관련한 사항

④ 각 기관의 장은 사이버보안담당관이 직무를 원활히 수행할 수 있도록 조직, 인력 (정보화업무 담당인력 대비 10% 이상) 및 예산(정보화 예산 대비 15% 이상)을 운영하여야 한다.

⑤ 각 기관의 장은 사이버보안담당관이 직무를 효율적으로 수행할 수 있도록 각 부서의 공무원등 중에서 부서의 사이버보안업무를 수행할 수 있는 적정인력을 분임사이버보안담당관으로 임명하여야 한다.

⑥ 기관별 각 부서의 장은 그 직위에 임명과 동시에 해당 부서의 분임사이버보안담당관에 임명된 것으로 본다.

⑦ 분임사이버보안담당관의 기본활동은 다음 각 호와 같다.

1. 부서에서 운용하는 홈페이지 등 정보화사업 보안관리 및 정기점검, 제60조 제1항, 제2항에 따른 홈페이지 등 게시자료 보안에 관한 사항

2. 부서원 개별 단말기·업무자료 보안관리 및 정기점검

3. '사이버보안진단의 날'에 소속 부서의 보안진단을 실시

4. 도메인 간 자료 전송 시 승인

5. 제56조 제1항에 따른 저장매체 불용처리에 관항 사항

6. 제68조 제8항에 따른 휴대용 저장매체 보안에 관한 사항

7. 제69조 제1항, 제2항에 따른 비인가 기기 통제에 관한 사항

8. 그 밖에 부서내 사이버보안에 관한 사항

제5조의2(연도 추진계획 수립) ① 각 기관의 장은 매년 사이버보안업무 추진계획을 수립·시행하여야 한다.

② 성평등가족부장관은 보안대책 수립 및 정보통신망 안전성 확인 등을 위하여 산하기관의 장에게 「연도 사이버보안업무 추진계획」의 제출을 요청할 수 있다.

③ 성평등가족부장관은 사이버보안 정책 및 계획을 수립·시행함에 있어 다른 기관과 협의·조정할 필요가 있을 경우 국가정보원장에게 「사이버안보 업무규정」 제3조의2제2항에 따른 조정을 요청할 수 있다.

제6조(사이버보안 세부지침) ① 성평등가족부장관은 「사이버안보 업무규정」 제8조에 따른 사이버보안 세부지침의 수립시에 산하기관의 사이버보안 업무를 규정할 수 있으며, 이 범위내에서 산하기관은 세부지침을 별도로 수립하지 아니할 수 있다.

② 제1항에 따라 사이버보안 세부지침을 제정할 경우 산하기관의 장은 성평등가족부장관과 사전 협의하여야 한다. 주요내용 개정시 협의가 필요하다고 판단하는 경우에도 같다.

③ <삭제>

제7조(사이버보안감사 등) ① 각 기관의 장은 사이버보안업무 및 활동을 조사·점검하기 위하여 연1회 이상 사이버보안감사를 실시하여야 하며, 이를 위하여 필요한 경우 사이버보안담당관을 감사 또는 감찰업무를 수행하는 부서에 배속하여 사이버보안감사를 수행하도록 할 수 있다.

② 성평등가족부장관은 산하기관에 대한 사이버보안감사를 실시할 수 있다.

③ 각 기관의 장은 제1항에 따른 사이버보안감사를 실시할 경우 제79조 제1항 및 [부록 1] 사이버보안점검 체크리스트 등을 활용할 수 있다.

④ 각 기관의 장은 사이버보안감사 담당자를 다음 각 호의 법규를 준용하여 우대하여야 한다.

1. 「공공감사에 관한 법률」 제18조에 따른 근무성적평정, 임용 등에서 우대
2. 「중앙행정기관 등의 자체감사 역량 강화에 관한 규정」(국무총리훈령) 제7조에 따른 전문역량 강화 및 제9조에 따른 근무성적평정·전보·수당 등에서 우대
3. 「자체감사활동의 지원 및 대행·위탁감사에 관한 규칙」(감사원규칙) 제4조제4호에 따른 근무여건 개선 및 사기제고

4. 「공기업·준정부기관 감사기준」(재정경제부) 제16조에 따른 감사 수당의 지급, 인사기준 별도 적용, 전보시 희망보직 우선 고려

⑤ 성평등가족부장관은 사이버보안감사 이외 산하기관의 사이버보안 업무에 필요한 경우 사이버보안 점검방문을 실시할 수 있다.

제8조(사이버보안교육) ① 각 기관의 장은 사이버보안에 대한 경각심을 제고하기 위하여 사이버보안 교육계획을 수립하여 연1회 이상 모든 소속 공무원등을 대상으로 교육(온라인 교육을 포함한다)을 실시하여야 한다.

② 제1항에 따라 모든 공무원등은 특별한 사유가 없는 한 연1회 이상 사이버보안교육을 이수하여야 한다.

③ 각 기관의 장은 제1항에 따라 사이버보안교육을 실시할 경우 해당 기관의 실정에 맞는 교육자료를 작성 활용한다.

④ 각 기관의 장은 사이버보안담당관, 분임사이버보안담당관 및 사이버보안 담당직원의 업무 전문성을 제고하고 소속 공무원등의 사이버보안 지식을 함양하기 위하여 전문기관의 교육 이수나 학술회의 참가 등을 장려하여야 한다.

제9조(사이버보안진단의 날) ① 각 기관의 장은 해당 기관의 실정에 맞게 매월 세 번째 수요일을 '사이버보안진단의 날'로 지정·시행하여야 한다. 다만, 부득이한 사유로 해당 일에 시행하지 못할 경우 같은 달 다른 날에 시행하여야 한다.

② 부서 분임사이버보안담당관은 사이버보안담당관 총괄 하에 '사이버보안진단의 날'에 소속 부서의 정보통신망과 정보시스템의 보안취

약 여부 확인 등 보안진단을 실시하여야 한다.

제2장 정보화사업 보안

제1절 사업 계획

제10조(보안책임) ① 각 기관에서 정보통신망 또는 정보시스템을 개발·구축·운용·유지 보수하는 사업(「지능정보화 기본법」 제11조제1항에 따른 지능정보화계획에 의한 사업을 포함한다. 이하 "정보화사업"이라 한다)을 담당하는 정보화사업담당관은 해당 정보화사업에 대한 보안관리를 수행하여야 한다.

② 정보화사업을 추진하는 부서의 장은 정보화사업에 대한 보안관리 책임을 지고 관리·감독하여야 한다.

③ 사이버보안담당관 및 보안담당관(「보안업무규정」 제43조에 따른 보안담당관을 말한다.)은 각종 정보화사업과 관련한 보안대책의 적절성을 평가하고 정보화사업 수행 전반에 대하여 보안대책의 이행여부를 점검하여 필요한 경우 정보화사업을 추진하는 부서의 장에게 시정을 요구할 수 있다.

제11조(보안대책 수립) 각 기관의 장은 정보화사업 계획을 수립할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 보안관리체계(조직, 인원 등) 구축 등 관리적 보안대책
2. 설치·운용장소 보안관리 등 물리적 보안대책
3. 정보통신망 또는 정보시스템의 구성요소별 기술적 보안대책

4. 긴급사태 대비 및 재난복구 계획

5. 용역업체 작업장소에 대한 보안대책

6. 온라인 개발 또는 온라인 유지보수가 필요하다고 판단할 경우, 제25조의2 또는 제47조에 따른 보안 준수사항

7. 누출금지정보 보안관리 방안

8. 국가정보원장이 개발하거나 안전성을 확인한 암호자재, 검증필 암호모듈 및 정보보호시스템 도입·운용계획

제12조(제안요청서 기재사항) ① 각 기관의 장은 용역업체에 정보화사업을 발주하기 위하여 제안요청서, 과업지시서 등 계약 상대방의 의무를 명시하는 서류를 작성할 경우 다음 각 호의 사항을 포함하여야 한다.

1. 용역업체 작업장소에 대한 보안요구사항

1의 2. 용역업체 인원 대상 자체 보안관리 방안

가. 비밀번호 관리 및 작업이력 점검

나. 사업 수행과 관련한 보안 교육

다. 보안서약서 징구·존안

라. 보안사고 발생시 위규자 처리

2. 온라인 개발 또는 온라인 유지보수가 필요하다고 판단할 경우, 제26조의2 또는 제47조에 따른 보안 준수사항

3. 누출금지정보 목록

4. 용역업체가 누출금지정보를 제외한 소프트웨어 산출물을 제3자에게 제공하고자 할 경우 발주자의 승인절차

② 제1항제3호에 따른 누출금지정보 목록을 작성할 경우 다음 각 호의

사항을 포함하여야 한다.

1. 해당 기관의 정보시스템 내·외부 IP주소 현황
2. 정보시스템 구성 현황 및 정보통신망 구성도
3. 관리자 및 개별사용자의 계정·비밀번호 등 정보시스템 접근권한 정보
4. 정보통신망 또는 정보시스템 취약점 분석·평가 결과물
5. 정보화사업 용역 결과물 및 관련 프로그램 소스코드(외부에 유출될 경우 국가안보 및 국익에 피해가 우려되는 중요 용역사업에 해당)
6. 암호자재 및 정보보호시스템 도입·운용 현황
7. 정보보호시스템 및 네트워크장비 설정 정보
8. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따라 비공개 대상 정보로 분류된 해당 기관의 내부문서
9. 「개인정보보호법」 제2조제1호에 따른 개인정보
10. 「보안업무규정」 제4조에 따른 비밀 및 「보안업무규정 시행규칙」 제16조제3항에 따른 대외비
11. 그 밖에 해당 기관의 장이 공개가 불가하다고 판단한 자료

제2절 보안성 검토

제13조(검토 시기 및 절차) ① 부서 분임사이버보안담당관 및 산하기관의 장은 정보화사업을 수행하고자 할 경우 정보화사업과 관련한 보안대책의 적절성을 평가하기 위하여 사업 계획 단계(사업 공고 전)에서 보안성 검토 절차를 이행하여야 한다.

② 부서 분임사이버보안담당관 및 산하기관의 장은 제1항에 따른 보안성 검토를 위하여 제 14조 제1항 및 제2항에 따른 보안성 검토를 성평등가족부장관에게 의뢰하거나 자체적으로 실시하여야 한다. 산하기관의 장이 [부록 5]「정보화사업 보안성검토 처리기준」의 국가정보원 대상 정보화사업에 해당하여 국가정보원장에게 보안성 검토를 의뢰하고자 할 경우 성평등가족부장관을 거쳐 의뢰하여야 한다.

③ 보안성 검토는 서면 검토를 원칙으로 하며 국가정보원장 또는 성평등가족부장관이 필요하다고 판단하는 경우 현장 확인을 병행 실시할 수 있다.

제14조(검토 기관) ① 성평등가족부장관은 해당 기관에서 추진하는 정보화사업 중 [부록 5]「정보화사업 보안성검토 처리기준」의 성평등가족부 보안성검토 대상 정보화사업에 대하여 보안성 검토를 실시한다.

② 산하기관의 장은 추진하는 정보화 사업 중 [부록 5]「정보화사업 보안성검토 처리기준」의 산하기관 보안성검토 대상 정보화사업에 대하여 보안성 검토를 실시한다.③ 성평등가족부장관은 제1항 및 제2항 따라 수행하는 성평등가족부 및 산하기관의 정보화사업 보안성 검토 대상 중에서 반복적으로 요청하는 유형에 대하여는 개별적 검토에 갈음하는 기준을 미리 작성·배포할 수 있으며, 정보시스템 책임관리자 및 산하기관의 장이 이를 준수하여 정보화사업 계획을 수립하였을 경우 제1항 및 제2항에 따른 보안성 검토 절차를 이행한 것으로 본다. 다만, 성평등가족부장관은 해당 정보화사업 현황을 파악하여 제17조의2조에 따른 제출시에 포함하여야 하며, 필요시 제17조에 따른 현장 점

검을 실시한다.

③ 삭제

제15조(검토 생략) ① 부서 분임사이버보안담당관 및 산하기관의 장은 다음 각 호에 해당하는 정보화사업에 대하여는 보안성 검토 절차의 이행을 생략할 수 있다. 이 경우 각 기관의 장은 관련 매뉴얼·가이드라인 등을 준수하는 등 자체 보안대책을 수립·시행하여야 한다.

1. [부록 5]「정보화사업 보안성검토 처리기준」 정보화사업에 해당하지 아니하는 단순 장비·물품 도입
2. 제14조에 따른 보안성 검토를 거쳐 완료한 정보화사업에 대하여 정보통신망 구성을 변경하지 아니하는 범위 내에서 다음 각 목의 사항을 포함한 후속운영·유지보수·컨설팅(단일 회선의 이중화는 본 호를 적용함에 있어 정보통신망 구성의 변경이 아닌 것으로 본다)
   가. 서버·스토리지·네트워크장비 등 장비 노후화로 인한 단순 장비 교체
   나. 전화기·무전기·CCTV 등 통신·영상기기의 노후화로 인한 단순 장비 교체
   다. 기존 운용하던 정보보호시스템을 동일한 보안기능을 보유한 다른 정보보호시스템으로 교체
   라. 사업자 변경, 임대 기한의 종료 등 단순 후속 운영을 위한 절차
3. 다년도에 걸쳐 계속되는 사업으로써 사업 착수 당시 보안성검토를 완료한 후 사업 내용의 변동 없이 계속 추진하는 운영·유지사업

4. PC・프린터 및 상용 소프트웨어 등 단순 제품 구매・교체・사용권한(라이선스) 기간연장 또는 사용자수 증감

② 부서 분임사이버보안담당관 및 산하기관의 장은 제1항제2호부터 제4호까지에 해당하는 정보화사업을 수행할 경우 기존 보안성 검토결과를 준수하여야 한다.

제16조(제출 문서) 부서 분임사이버보안담당관 및 산하기관의 장은 제13조제2항에 따라 보안성 검토를 의뢰할 경우 다음 각 호의 사항이 포함된 문서를 제출하여야 한다.

1. 사업계획서(사업목적 및 추진계획을 포함한다)
2. 제안요청서
3. 정보통신망 구성도(필요시 IP주소체계를 추가한다)
4. 자체 보안대책(N2SF, 클라우드 및 AI 관련 정보화사업은 해당 보안가이드라인의 체크리스트・산출물 등을 포함한다)

제17조(검토결과 조치) ① 부서 분임사이버보안담당관 및 산하기관의 장은 제14조에 따라 보안성 검토결과를 통보받은 경우 검토결과를 반영하여 보안대책을 보완하여야 한다.

② 성평등가족부장관은 제1항에 따른 보안성 검토결과 반영여부를 확인하기 위하여 현장 점검을 실시할 수 있다.

제17조의2(현황 제출) ① 산하기관의 장은 전년도에 실시한 정보화사업에 대한 보안성 검토결과 현황을 매년 1. 20까지 성평등가족부장관에게 제출하여야 한다.

② 성평등가족부장관은 해당 기관 및 산하기관의 전년도에 실시한 정

보화사업에 대한 보안성 검토결과 현황을 매년 1.25까지 국가정보원에 제출하여야 한다.

제3절 제품 도입

제18조(정보통신제품 도입) ① 각 기관의 장은 정보 및 정보통신망 등을 보호하기 위하여 보안기능이 있는 다음 각 호의 정보통신제품을 도입할 수 있다.

1. 제19조에 따른 안전성 검증필 제품 목록에 등재되어 있는 제품
2. 비밀이 아닌 업무자료의 암·복호화를 목적으로 한 경우 검증필 암호모듈 탑재 등 도입요건을 만족하는 제품
3. 제1호 및 제2호에 해당하지 않는 정보통신제품 중에서 국가정보원장이 별도로 공지하는 도입요건을 만족하는 제품
4. 제품유형의 특성상 보안기능의 비중이 미미하여, 각 기관의 장이 자유롭게 도입·운용이 가능한 '단순 보안기능 제품유형'으로 국가정보원장이 공지한 제품
5. 제79조의2 제2항에 따라 취약 정보통신제품을 긴급 대체하기 위하여 도입하는 제품

② 제1항제3호에 해당하는 제품은 실제 적용·운용 이전에 제2장제5절에 따른 보안적합성 검증을 받아야 한다.

③ 제1항제5호에 해당하는 긴급 대체 제품을 도입한 기관의 장은 빠른 시일내에 원(原) 제품과 동일 수준의 안전성 확인이 이루어질 수 있도록, 대체 제품에 대하여 제1항제1호 또는 제2호에 따른 도입요건을 갖

추도록 하거나 제3호 또는 제2장제5절에 따른 보안적합성 검증 절차를 거치도록 하여야 하며, 필요시 국가정보원장에게 추가적인 검증을 요청할 수 있다.

제19조(안전성 검증필 제품 목록) 각 기관의 장은 국가정보원장이 다음 각 호의 어느 하나에 해당하는 정보통신제품을 안전성 검증필 제품 목록에 등재하여 공지한 도입요건을 준수하여야 한다.

1. 국가정보원장이 홈페이지 등을 통해 공지한 안전성 검증필 제품 목록 등재 기본요건을 준수하는 제품
2. 국가정보원장이 개발하고 안전성을 확인하여 기술 이전한 정보통신제품

제20조(검증필 암호모듈 목록) 각 기관의 장은 국가정보원장이 검증필 암호모듈 목록에 등재한 상용 암호모듈 사용을 준수하여야 한다.

제21조(영상정보처리기기 도입) 각 기관의 장은 제72조제1항에 따른 영상정보처리기기를 도입하고자 할 경우 제18조제1항제1호에 따른 제품을 도입하여야 한다.

제22조(도입현황 제출) 성평등가족부장관은 각 기관에서 도입한 제18조에 따른 정보통신제품에 대하여 국가정보원장이 홈페이지 등을 통해 공지한 정보통신제품 도입 확인서(현황)를 작성·존안하고, 제출이 필요한 경우 국가정보원장에게 제출하여야 한다.

제22조의2(상용소프트웨어 도입) ① 각 기관의 장은 「상용소프트웨어 제3자단가계약 추가특수조건」(조달청 지침) 제2조제2호에 따른 제3자단가계약으로 상용소프트웨어를 도입하고자 할 경우, 같은 지침 제1

0조제4항에 따른 판매중지 여부를 확인하여야 한다.

② 각 기관의 장은 상용소프트웨어 도입 시 다음 각 호의 사항을 계약사항에 포함하여야 한다. 다만, 조달청을 통한 구매에 이미 해당사항이 반영된 경우에는 생략할 수 있다.

1. SW 구매계약 : 해당제품에 보안취약점이 발견된 경우 제조사·판매사에 시정조치를 요구할 수 있다.
2. 제조사와 최종사용자 간에 최종사용자 사용권 계약 : 제조사는 최종사용자가 사용하는 제품의 보안취약점을 알게 될 경우 시정할 의무가 있다.
3. '발주처-공급업체(판매자)-제조사' 3자 간에 기술지원 확약서(또는 협약서) : 해당제품에 보안취약점이 발견된 경우 제조사·공급업체(판매자)에 기술지원을 요청할 수 있다.

제22조의3(클라우드컴퓨팅 도입 가능 목록) 각 기관의 장이 도입·운영 또는 이용할 수 있는 클라우드컴퓨팅 서비스는 다음 각 호의 모든 보안기준(이하 '국가 클라우드컴퓨팅 보안기준'이라 한다.)을 충족시키는 것을 말한다.

1. 국내에 위치한 정보시스템(인증서버, 로그 및 백업서버 등)에 데이터가 저장·관리되고, 국내에 위치한 인력이 관리하는 서비스
2. 다음 각목의 요건을 충족하는 서비스
   가. 일반 이용자용 서비스와 데이터 및 프로세스 등의 간섭없이 국가정보원 및 이용기관의 보안관제, 사고조사, 예방보안활동 유지를 위한 제반 환경을 만족하도록 영역을 분리할 것

나. 분리 방식 : ‘시스템 중요도’에 따라 물리적 또는 논리적으로 구현다. ‘시스템 중요도’ 분류는 [별표 4]의 기준 준용

3. 클라우드컴퓨팅 서비스가 안보위해 공격을 행하거나 행할 우려가 있는 자와 경영상 또는 기술적 연계점이 없을 것

4. 그밖에 「국가 클라우드컴퓨팅 보안 가이드라인」에 명시된 국가 클라우드 보안기준 준수

제22조의4(클라우드컴퓨팅 서비스의 도입·운영·이용) ① 각 기관의 장은 민간 클라우드컴퓨팅 서비스를 이용하고자 할 경우 제22조의3에 따라 클라우드컴퓨팅 도입 가능 목록에 등재된 민간 클라우드컴퓨팅 서비스를 이용하여야 한다.

② 각 기관의 장은 민간 클라우드컴퓨팅 서비스 사업자와 계약 시 해킹사고 및 장애 대응, 재발 방지 등에 필요한 조치를 위해 국가정보원 및 이용기관의 보안관제 및 사고조사, 사이버공격 및 위협에 대한 예방 및 대응활동 등에 적극 협조하도록 하는 내용을 계약사항에 명시하여야 한다.

제4절 계약 및 사업수행

제23조(계약 특수조건) ① 각 기관의 장은「국가를 당사자로 하는 계약에 관한 법률 시행령」제76조제2항제3호다목에 따른 정보통신망 또는 정보시스템 구축 및 유지보수 등의 계약을 체결하는 경우, 다음 각 호의 행위를 금지하는 계약 특수조건을 계약서에 명시하여야 한다.

1. 정보통신망 또는 정보시스템에 허가 없이 접속하거나 무단으로 정

보를 수집할 수 있는 비인가 프로그램을 설치하는 행위

2. 제1호의 행위에 악용될 수 있는 정보통신망 또는 정보시스템의 약점을 고의로 생성하거나 방치하는 행위

② 각 기관의 장은 계약기간(하자보증기간을 포함한다) 내에 발생한 보안 약점에 대하여 계약업체로 하여금 개선 조치를 하도록 하여야 한다.

③ 각 기관의 장은 필요한 경우 계약업체로부터 제1항과 관련한 행위가 없다는 대표자 명의의 확약서를 요구할 수 있다.

제24조(용역업체 보안) ① 각 기관의 장은 용역업체에 정보화사업을 발주할 경우 다음 각 호의 보안사항을 준수하도록 계약서에 명시하여야 한다.

1. 제12조제1항 각 호에 따른 제안요청서에 포함된 사항

1의2. 제26조에 따른 원격지 개발, 제26조의2에 따른 원격지에서의 온라인 개발, 제47조에 따른 온라인 유지보수를 허용할 경우 보안 준수사항

2. 소프트웨어 개발보안에 필요한 사항

3. 사업 참여인원의 보안관련 준수사항과 위반할 경우 손해배상 책임에 관한 사항

4. 사업기간 중 참여인원 임의교체 금지

5. 정보통신망 구성도·IP주소 현황 등 업체에 제공하는 자료는 자료인계인수대장을 비치하여 보안조치 후 인계·인수하고 무단 복사 및 외부반출 금지

6. 업체의 노트북·휴대용 저장매체 등 관련 장비는 반출·입시마다

악성코드 감염여부, 누출금지정보 무단 반출여부 등 점검

7. 사업 종료시 업체의 노트북·휴대용 저장매체 등 관련 장비는 저장자료 복구가 불가하도록 완전 삭제

8. 사업 종료 시 누출금지정보 전량 회수

9. 그 밖에 해당 기관의 장이 보안관리가 필요하다고 판단하는 사항

② 각 기관의 장은 비밀 및 중요 용역사업을 수행할 경우 용역업체 참여인원이 다음 각 호에 해당되는 사실을 알게 된 경우 교체를 요구하여야 한다.

1.「국가공무원법」제33조 각 호에 해당하는 사람

2.「국가를 당사자로 하는 계약에 관한 법률」제27조제1항 각 호의 행위를 한 사람

③ 각 기관의 장은 다음 각 호에 따른 보안 준수사항의 이행여부를 정기 또는 수시로 점검(불시 점검을 포함한다)하고 미비점을 발견한 경우 용역업체로 하여금 시정 조치하도록 하여야 한다. 이 경우 정보화사업담당관이 점검한 후 그 결과를 사이버보안담당관에게 통보하여야 한다.

1. 제1항에 따라 계약서에 명시된 보안 준수사항

2. 제25조의2에 따른 발주기관내 작업장소 보안 준수사항

3. 제26조에 따른 원격지 개발 보안 및 제26조의2에 따른 원격지에서의 온라인 개발시 보안 준수사항

4. 제46조에 따른 정보시스템 유지보수 및 제47조에 따른 온라인 유지보수시 보안 준수사항

④ 성평등가족부장관은 해당 기관 및 산하기관에 대하여 용역업체 보안관리 실태 점검을 실시할 수 있으며, 필요한 경우 국가정보원장에게 지원을 요청할 수 있다.

⑤ 각 기관의 장은 제3항 및 제4항에 따른 점검 결과 용역업체 보안대책 준수가 미흡하고 시정조치가 어렵다고 판단할 경우 제26조에 따른 원격지 개발, 제26조의2에 따른 원격지에서의 온라인 개발 또는 제47조에 따른 온라인 유지보수 허가를 취소하거나 계약 상 유보된 해지권리에 따라 계약을 해지할 수 있다.

⑥ 각 기관의 장은 제26조의2에 따른 원격지에서의 온라인 개발, 제47조에 따른 온라인 유지보수를 허용하고자 할 경우에는 용역업체의 온라인 접속을 통제하기 위한 온라인 용역 통제시스템을 구축·운영하여야 한다.

⑦ 그 밖에 용역업체 보안과 관련한 사항은 국가정보원장이 배포한「국가·공공기관 용역업체 보안관리 가이드라인」을 준수하여야 한다.

제25조(소프트웨어 개발보안) 각 기관의 장은 정보시스템을 개발할 경우 「전자정부법」 제45조제3항에 따라 규정된「행정기관 및 공공기관 정보시스템 구축·운영 지침」(행정안전부 고시) 제50조부터 제53조까지에 따라 보안약점이 발생하지 아니하도록 개발(이하 "소프트웨어 개발보안"이라 한다)하고 정보시스템 감리 등을 통해 보안약점을 진단하여야 한다.

제25조의2(발주기관내 작업장소 보안) ① 각 기관의 장은 발주기관내(기관장이 임차한 외부 사무실을 포함한다) 용역업체 작업장소를 설치

할 경우 보안 통제가 가능한 공간을 마련, 운영하여야 한다.

② 발주기관내 용역업체 작업장소에 설치 운영하는 정보통신망은 발주기관의 정보통신망과 분리 구성하여야 한다. 다만, 용역업체가 사업수행을 위하여 발주기관 정보시스템 이용이 불가피할 경우에는 필요한 정보시스템에 한해 지정된 단말기로부터의 제한적 접근을 허용하는 등 보안대책을 수립·시행하여야 하며, 이 경우 기밀등급 또는 민감등급 정보시스템에 대한 접근 허용에 관하여는 국가정보원장과 사전 협의하여야 한다.

③ 작업장소내 정보시스템은 용역사업 수행을 위해 필요한 경우 해당 정보화사업담당관의 보안통제하에 인터넷에 연결할 수 있다. 다만, 제2항 단서에 따른 발주기관 정보시스템 접근용 단말기의 경우에는 인터넷 연결을 금지한다.

④ 각 기관의 장은 용역업체가 발주기관 내 작업장소에서 개발 작업을 수행하더라도 개발용 서버가 민간 클라우드컴퓨팅서비스를 이용하는 등으로 원격지에 위치할 경우 원격지 개발로 간주하고 제26조제1항에 따른 보안대책을 수립·시행하여야 한다. <개정 2023. 4. 14.>

제26조(원격지 개발보안) ① 각 기관의 장은「소프트웨어 진흥법」제49조제3항 및 제4항,「소프트웨어사업 계약 및 관리감독에 관한 지침」제14조에 따라 용역업체가 발주기관 이외 장소(이하 "원격지"라 한다)에서 개발 작업(유지보수는 제외한다)을 수행하고자 요청할 경우 제12조제1항제1호에 따른 용역업체 작업 장소에 대한 보안요구사항 등을 포함한 관리적·기술적 보안대책을 수립·시행하여야 한다. 이 경우

정보화사업담당관은 보안대책을 수립한 후 사이버보안담당관의 승인을 받아야 한다.

② 원격지내 정보시스템은 개발 작업을 위하여 필요한 경우 해당 정보화사업담당관의 보안통제 하에 인터넷에 연결할 수 있다.

제26조의2(원격지에서의 온라인 개발) 제26조에 따른 원격지 개발시 기관의 장이 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한하여, 각 기관의 장은 용역업체에 원격지에서 인터넷을 통해 발주기관 정보시스템에 온라인 접속한 상태의 개발 작업을 허용할 수 있다.

1. 지정된 단말기에서만 접속 및 해당 단말기에 대한 접근인원 통제
2. 지정 단말기는 다음 각 목의 어느 하나에 해당하는 경우에 접속을 허용하고 그 외의 접속은 차단
   가. 제3호에 따른 온라인 용역 통제 시스템
   나. 개발 수행에 불가피하고 신뢰성이 검증된 사전 보안대책이 마련된 인터넷 서비스
3. 발주기관내 설치된 온라인 용역 통제시스템을 경유하여 개발에 필요한 정보시스템에 접속하는 등 소통구간 보호·통제
4. 접속사실이 기록된 로그기록을 1년 이상 보관
5. 계약 시행일로부터 종료 후 30일이 경과하는 날까지의 기간 중에 발주기관, 성평등가족부 및 국가정보원의 정기 또는 수시 보안점검(불시 점검을 포함한다) 수검
6. 기타 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리

가이드라인」에서 제시된 온라인 개발에 관련된 보안대책의 준수

제27조(소프트웨어 산출물 제공) ① 각 기관의 장은 용역업체가「소프트웨어진흥법」제59조 및 「(계약예규)용역계약일반조건」) 제56조에 따른 지식재산권을 행사하기 위하여 소프트웨어 산출물의 반출을 요청할 경우 제안요청서 또는 계약서에 명시된 누출금지정보에 해당하지 아니하면 제공하여야 한다.

② 각 기관의 장은 제1항에 따라 소프트웨어 산출물을 용역업체에 제공할 경우 업체의 노트북・휴대용 저장매체 등 관련 장비에 저장되어 있는 누출금지정보를 완전 삭제하여야 하며 업체로부터 누출금지정보가 완전 삭제되었다는 대표자 명의의 확약서를 받아야 한다.

③ 각 기관의 장은 용역업체가 소프트웨어 산출물을 제3자에게 제공하고자 할 경우 제공하기 이전에 승인을 받도록 하여야 한다.

④ 그 밖에 소프트웨어 산출물 제공과 관련한 사항은「소프트웨어사업 및 관리감독에 관한 지침(과학기술정보통신부 고시)」제32조를 준수하여야 한다.

제28조(누출금지정보 유출시 조치) ① 각 기관의 장은 용역업체가 제안요청서 또는 계약서에 명시된 누출금지정보를 유출한 사실을 인지한 경우 업체를 대상으로 계약 위반에 따른 조치를 취하여야 한다. 이 경우 용역업체의 누출금지정보 유출 사실을 인지한 정보화사업담당관 또는 사업과 관계된 공무원 등은 즉시 사이버보안담당관을 거쳐 소속 기관의 장에게 보고하여야 한다.

② 제1항에 따라 용역업체의 누출금지정보 유출 사실을 인지하거나

보고를 받은 기관의 장은 그 사실을 성평등가족부장관 및 국가정보원장에게 통보하여야 하고 직접 또는 성평등가족부장관을 통하여 「국가를 당사자로 하는 계약에 관한 법률 시행령」 제76조 및 「지방자치단체를 당사자로 하는 계약에 관한 법률 시행령」 제92조에 따라 입찰 참가자격 제한 등 관련조치를 취하여야 한다.

제5절 보안적합성 검증

제29조(검증 대상 제품) 각 기관의 장은 제18조제1항제3호에 따른 보안기능이 있는 정보통신제품을 도입하는 경우 실제 적용·운용 이전에 안전성을 확인하기 위하여 보안적합성 검증을 받아야 한다.

제30조(검증기관 및 신청) 각 기관의 장은 제29조에 따른 보안적합성 검증을 받고자 할 경우 국가정보원장에게 검증을 신청할 수 있다.

제31조 삭제

제32조 삭제

제33조 삭제

제34조 삭제

제35조 삭제

제3장 정보통신망 및 정보시스템 보안

제1절 국가 망 보안체계(N2SF)

제35조의2(업무정보의 등급식별) ① 각 기관의 장은 다음 각 호의 사항을 기준으로 해당 기관의 업무 기능을 식별하고 분류하여야 한다.

1. 「정부기능의 분류 및 관리에 관한 규정」(대통령훈령) 및 「정부기능분류시스템(BRM) 운영 지침」(행정안전부 예규)에 따라 행정안전부장관이 분류하는 '정부기능별 분류체계'
2. 「공공기관의 데이터베이스 표준화 지침」(행정안전부 고시)
3. 기관 자체의 기능분류체계

② 각 기관의 장은 제1항에 따라 분류된 업무기능별 취급되는 업무정보를 기밀등급·민감등급·공개등급으로 분류하여야 한다.

③ 각 기관의 장은 제1항에 따른 업무기능을 분류함에 있어서는 해당 업무에서 취급하는 업무정보의 보안등급이 명확히 구별될 수 있을 정도로 가급적 소기능 수준까지 세분화하여야 한다.

④ 제1항 및 제2항에도 불구하고 각 기관의 장은 업무정보의 등급을 분류하는 경우에 다음 각 호에 따라 그 등급을 상향 조정할 수 있다.

1. 공개 또는 민감등급의 개별 정보가 상위 등급의 정보와 집합, 결합되거나 연계되는 경우
2. 공개 또는 민감등급의 개별 정보가 동일 등급의 정보와 집합, 결합되거나 연계되어 중요도 내지 침해 영향이 향상된 경우

제36조 삭제

제36조의2(업무정보의 처리) ① 각 업무정보는 해당 등급보다 같거나 높은 등급의 정보시스템 또는 도메인에서 처리되어야 한다. 다만, 「국가 망 보안체계 보안 가이드라인」 내에 보안통제 항목을 준수하는 경우 업무정보 등급보다 낮은 등급의 정보시스템 또는 도메인에서 처리할 수 있다.

② 단일 정보시스템 또는 도메인 내에는 가급적 단일 등급의 업무정보들이 처리되어야 한다. 이를 위해 단일 정보시스템 또는 도메인 내에서 서로 다른 등급의 업무정보의 혼용을 최소화하여야 한다.

제36조의3(정보시스템의 위치) 단일한 도메인내에서는 가급적 단일 등급의 정보시스템이 위치하도록 하여야 한다. 이를 위해 단일한 도메인 내에서 서로 다른 등급의 정보시스템의 혼용을 최소화하여야 한다.

제36조의4(보안통제) ① 도메인(Domain), 정보시스템, 업무정보의 등급별 보안통제(이하 "국가 망 보안체계(N2SF, National network Security Framework)"라 한다)에 관하여는 이 지침에서 별도로 정함이 없으면 국가정보원장이 배포한 「국가 망 보안체계 보안가이드라인」에 보안통제 항목을 따른다.

② 각 기관의 장은 제1항에 따른 국가 망 보안체계의 보안통제 항목을 구현하기 위하여 서로 다른 등급의 도메인 또는 정보시스템간 통신을 차단하거나 분리할 수 있다.

③ 각 기관의 장은 제1항에 따른 국가 망 보안체계의 보안통제 항목에 위배되지 않는 범위에서 공개등급 도메인·정보시스템을 외부 인터넷과 통신이 이루어지게 하거나, 공개등급 정보시스템을 외부 인터넷에 둘 수 있다.

제37조(클라우드컴퓨팅 보안) ① 각 기관의 장은 클라우드컴퓨팅을 자체 구축·운영하고자 할 경우(타 기관 등과 공동으로 구축·운영하는 경우를 포함한다) 국가정보원장이 배포한「국가 클라우드 컴퓨팅 보안 가이드라인」에 명시된 국가 클라우드 보안 기준에 따라 보안대책

을 수립·시행하여야 한다.

② 제22조의4에 따라 민간 클라우드컴퓨팅서비스를 이용하는 기관의 장은 클라우드컴퓨팅 서비스제공자에 의하여 누출금지정보가 유출된 경우 제28조에 따른 조치를 취하여야 한다.

③ 제22조의4제1항에 따른 민간 클라우드컴퓨팅서비스의 제공자는 해당 각 기관이 이용하는 클라우드 영역에 대해 정부 기관에 준하는 보안관리 책임을 진다.

④ 삭제

⑤ 삭제

⑥ 삭제

제38조(보안·네트워크장비 보안) ① 각 기관의 장은 침입차단·탐지시스템, 스위치·라우터 등 기관 정보통신망 구성 또는 기관 사이버보안 정책 전반에 영향을 미치는 보안·네트워크 장비를 설치·운용하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 물리적으로 안전한 장소에 설치하여 비(非)인가자의 무단접근 통제
2. 콘솔에서 관리함을 원칙으로 하되, 다음 각 목의 경우 청사 내 지정 단말기로부터의 접속 관리 허용

   가. 장비 관리자의 접속

   나. 제25조의2제2항 단서에 따른 발주기관내 용역업체 작업장소에서의 접속
3. 최초 설치할 경우 디폴트(default) 계정은 삭제하거나 변경 사용하

고 장비 관리를 위한 관리자 계정을 별도로 생성·운영

4. 불필요한 서비스 포트와 개별사용자 계정은 차단 및 삭제

5. 펌웨어 무결성과 컴퓨터 운영체제·소프트웨어의 취약점 및 버전 업데이트 여부를 정기적으로 점검하고 최신 버전으로 유지

② 보안·네트워크장비 관리자는 로그기록을 1년 이상 유지하여야 하고 비(非)인가자의 접속여부를 정기적으로 점검하여 그 결과를 사이버보안담당관에게 통보하여야 한다.

③ 보안·네트워크장비 관리자는 침입차단·탐지시스템의 침입차단·탐지규칙(rule)의 생성 근거를 유지하고 정기적으로 필요성 여부를 점검·갱신하여야 한다.

제39조(무선랜 보안) ① 각 기관의 장은 기관 정보통신망 영역에서 다음 각 호의 상황에 따라 중계기(AP)를 구분하여 설치하는 방법으로 청사 내에 무선랜(WiFi)을 구축·운용할 수 있다

1. 공개등급 및 민감등급 영역 : 제64조제1항에 따라 해당 기관의 장이 지급한 단말기의 접속만을 허용하는 업무용 중계기(AP)

2. 공개등급 영역 : 제69조제1항 각 호에 따라 반입한 공무원등의 개인소유 이동통신단말기의 접속만을 허용하는 중계기(AP)

3. 공개등급 영역 상 별도 상용 인터넷망 : 외부인 전용(專用) 중계기(AP)

② 각 기관의 장은 제1항에 따라 무선랜을 구축·운용하고자 할 경우 국가정보원장이 배포한 「국가 망 보안체계 보안 가이드라인」을 준수하여 보안대책을 수립·시행하여야 한다.

③ 제2항에 따른 보안대책을 수립할 경우 제1항제1호 및 제2호에 따른 무선랜에 대하여는 다음 각 호의 사항을 포함하여야 한다.

1. 네트워크 이름(SSID) 브로드캐스팅(broadcasting) 금지
2. 추측이 어렵고 복잡한 네트워크 이름(SSID) 사용
3. WPA2 이상(256비트 이상)의 암호체계를 사용하여 소통자료 암호화
4. 비(非)인가 단말기의 무선랜 접속 차단 및 무선랜 이용 단말기 식별 기술을 적용하고, 관련 로그 기록 유지
5. IEEE 802.1X, AAA(Authentication Authorization Accounting) 등의 기술에 따라 상호 인증을 수행하는 무선랜 인증제품 사용
6. 무선침입방지시스템 설치 등 침입 차단대책
7. 기관의 내부에 해당하는 물리적 영역에서 사용하는 단말기가 해당 영역의 중계기(AP) 이외 중계기로의 접속을 차단하는 기술적 보안대책
8. 그 밖에 무선랜 단말기·중계기(AP) 등 구성요소별 분실·탈취·훼손·오용 등에 대비한 관리적·물리적 보안대책
9. 기관의 공개등급 또는 민감등급 영역 중계기(AP)에 단말기를 접속하는 경우 공개등급 영역 중계기(AP)와 민감등급 영역 중계기(AP)에 혼용하여 접속되지 않도록 하는 기술적·관리적 보안대책

④ 부서 분임사이버보안담당관은 제2항 및 제3항에 따른 보안대책의 적절성을 수시로 점검·보완하여야 한다.

제40조(이동통신망 보안) ① 각 기관의 장은 이동통신망·위성통신망(LTE·5G·6G 등)을 이용하여 시스템을 구축하거나 기밀등급 또는

민감등급 업무자료를 소통하고자 할 경우 암호화 및 비인가 단말기의 이동통신망·위성통신망 접속 차단 등 기술적 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 제1항에 따라 이동통신망·위성통신망을 이용한 시스템을 구축·운용할 경우 해당 기관의 정보통신망과 혼용되지 않도록 하여야 한다.

제41조(영상회의 보안) ① 각 기관의 장은 영상회의시스템을 구축·운용하고자 할 경우 통신망(국가정보통신망·전용(專用)선·인터넷 등) 암호화 등 보안대책을 수립·시행하여야 한다.

② 기타 영상회의시스템 보안과 관련한 사항은 국가정보원장이 배포한「안전한 정보통신 환경 구현을 위한 네트워크 구축 가이드라인」을 준수하여야 한다.

③ 각 기관의 장은 다음 각 호의 구분에 따라 상용 소프트웨어에 탑재된 영상회의 서비스를 이용할 수 있다.

1. 민감등급 업무정보를 취급하거나 회의 내용이 민감등급 업무정보에 준하다고 판단할 경우 : 영상·음성·업로드 데이터가 국내 서버로만 전송되는 상용 영상회의 소프트웨어(이하 "국내 영상회의 솔루션"이라 한다)를 활용
2. 공개등급 업무정보를 취급하거나, 회의 내용이 공개등급 업무정보에 준하다고 판단할 경우 : 국내 영상회의 솔루션 또는 그 밖의 영상회의 소프트웨어를 활용

④ 전항 제1호에도 불구하고, 각 기관의 장 은 다음 각 호의 어느 하나

에 해당하는 등 정당한 사유가 있는 경우 국가정보원장과 협의하여 국내 영상회의 솔루션 外의 소프트웨어를 일시적 또는 정기적으로 활용할 수 있다.

1. 안보·국익상 필요한 외국기관(외국軍을 포함한다)과의 영상회의시에 상대방이 국내 영상회의 솔루션을 활용할 수 없거나, 상대방이 국내 영상회의 솔루션 外의 소프트웨어 활용을 제안할 경우
2. 정책자문 등의 목적으로 민간인과 영상회의시에 상대방이 국내 영상회의 솔루션을 활용할 수 없는 경우
3. 국제기구 및 국제단체와의 상호 협약 또는 합의에 따라 지정된 상용 영상회의 서비스를 활용해야 하는 경우

⑤ 기타 영상회의 보안과 관련한 사항은 국가정보원장이 배포한「원격업무 통합보안매뉴얼」을 준수하여야 한다.

제42조(인터넷전화 보안) ① 각 기관의 장은 인터넷전화시스템을 구축·운용하거나 민간 인터넷전화 사업자망을 이용하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 한국정보통신기술협회(TTA) verified ver.4 이상 보안규격으로 인증받은 행정기관용 인터넷전화시스템 설치·운용
2. 인터넷전화기에 대한 장치 및 사용자 인증
3. 제어신호 및 통화내용 등 데이터 암호화
4. 인터넷전화망과 다른 정보통신망과의 분리
5. 인터넷전화 전용(專用) 침입차단시스템 등 정보보호시스템 설치·운용

6. 백업체제 구축

② 각 기관의 장은 민간 인터넷전화 사업자망을 이용할 경우 해당 사업자로 하여금 서비스 제공 구간에 대한 보안대책을 수립하도록 하여야 한다.

③ 기타 인터넷전화 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 인터넷전화 보안 가이드라인」을 준수하여야 한다.

제43조(인터넷 사용제한) ① 각 기관의 장은 국가비상사태 및 대형 재해·재난의 발생, 사이버공격·위협 등으로부터 정보통신망과 정보시스템의 정상적인 운영을 보장하기 위하여 소속 공무원등에 대한 인터넷 사용을 일부 제한할 수 있다.

② 각 기관의 장은 공개등급 정보시스템 단말기의 효율적인 운영 관리 및 악성코드 유입 차단을 위하여 게임·음란·도박 등 업무와 관련이 없는 인터넷 이용을 차단하여야 하며, 악성코드 유입 차단을 위하여 필요할 경우 제57조제4항에 따른 상용 정보통신서비스의 접속을 제한할 수 있다.

제44조(파견자용 정보통신망) ① 각 기관의 장은 다른 기관에 파견된 소속 공무원등의 활용을 위하여 파견기관의 장과 협의하여 원(原) 소속 기관의 정보통신망 전용(專用) 단말기를 파견기관에 설치·운영할 수 있다.

② 각 기관의 장은 제1항에 따라 단말기를 설치할 경우 단말기와 기관 정보통신망간 소통내용을 보호하여야 한다.

③ 제1항에 따라 각 기관의 기밀등급 또는 민감등급 업무정보를 처리

하는 단말기는 이 지침을 적용함에 있어 각각 원(原) 소속 기관의 해당 등급 정보시스템으로 본다.

④ 제1항에 따라 각 기관의 공개등급 업무정보를 처리하는 단말기는 이 지침을 적용함에 있어 원(原) 소속 기관의 해당 등급 정보시스템으로 본다.

제2절 정보시스템 보안

제45조(정보시스템 보안책임) ① 각 기관의 장은 정보시스템(PC・서버・네트워크장비・정보통신기기 등을 포함한다)을 도입・운용할 경우 해당 정보시스템에 대하여 관리자 및 관리책임자를 지정・운영하여야 한다.

② 정보시스템 관리자 및 관리책임자는 서버・네트워크장비 등 부서가 공동으로 사용하는 정보시스템의 운용・관리에 대한 보안책임을 진다.

③ 정보시스템 관리책임자는 정보시스템을 실제 운용하는 부서의 장이 되며 정보시스템 관리자는 관리책임자가 정한다. 관리책임자는 [서식 제4호]에 따른 정보시스템 관리대장을 수기 또는 전자적으로 작성・관리하여야 한다.

④ 정보시스템 관리책임자는 해당 부서의 [서식 제4호]에 따른 정보시스템 관리대장에 정보시스템의 최종 변경 현황을 유지하여야 하며 사본 1부를 사이버보안담당관에게 제출하여야 한다.

⑤ 사이버보안담당관은 정보시스템 운용과 관련하여 보안취약점을 발

견하거나 보안대책 수립이 필요하다고 판단하는 경우 개별사용자, 정보시스템 관리자 및 관리책임자에게 개선 조치를 요구할 수 있으며 조치가 완료될 때까지 정보시스템의 운용을 일시 제한할 수 있다.

제46조(정보시스템 유지보수) ① 정보시스템 관리책임자는 정보시스템의 유지보수 시 다음 각 호의 절차를 준수하여야 한다.

1. 유지보수 인원에 대한 보안서약서 집행, 보안교육 등을 포함한 유지보수 인가 절차를 마련하고 인가된 인원만 유지보수에 참여
2. 결함이 의심되거나 발생한 결함, 예방 및 유지보수에 대한 기록 유지
3. 유지보수를 위하여 정보시스템을 원래 설치장소에서 다른 장소로 이동할 경우 통제수단 마련
4. 유지보수 일시 및 담당자 인적사항, 출입통제 조치사항, 작업수행 내용 등 기록 유지

② 정보시스템 관리자는 용역업체 등이 유지보수와 관련한 장비·도구 등을 제25조의2제1항에 따른 발주기관내 용역업체 작업장소로 반출·반입할 경우 악성코드 감염여부 및 자료 무단 반출여부 확인 등 보안조치를 실시하여야 한다.

③ 정보시스템 관리자는 직접 또는 용역업체를 활용하여 정보시스템을 유지보수 할 경우 콘솔 또는 지정된 단말기로부터의 접속만을 허용하여야 한다.

④ 각 기관의 장은 소관 정보시스템에 대하여 중요도·가용성 등에 따라 등급을 분류하고 해당 등급에 맞게 정보 보존 및 관리, 장애관리, 보안관리 등을 수행하여야 한다.

제47조(지정 단말기를 통한 온라인 유지보수) ① 제46조제3항에 따른 지정된 단말기를 통해 유지보수를 함에 있어 각 기관의 장이 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한하여, 각 기관의 장은 용역업체에게 민감등급 정보시스템을 포함한 소관 정보시스템(제38조제1항에 따른 보안·네트워크장비를 제외한다)에 대하여 인터넷을 통한 온라인 유지보수를 허용할 수 있다.

1. 지정된 장소에 설치된 지정된 단말기에서만 접속 및 다중인증 등을 통한 해당 단말기 대상 접근인원 통제
2. 지정 단말기는 제3호에 따른 온라인 용역 통제시스템 접속 전용(專用)으로 운용하고 다른 목적의 인터넷 접속은 차단
3. 발주기관내 설치된 온라인 용역 통제시스템을 경유하여 유지보수 대상 정보시스템에 접속하는 등 소통구간 보호·통제
4. 접속사실이 기록된 로그기록을 1년 이상 보관
5. 유지보수 계약 시행일로부터 종료 후 30일이 경과하는 날까지의 기간 중에 발주기관, 성평등가족부장관 및 국가정보원장이 정기 또는 수시 점검(불시 점검을 포함한다) 수검
6. 기타 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」에서 제시된 온라인 유지보수에 관련된 보안대책의 준수

② 전항 제2호 및 제3호에도 불구하고 온라인 용역 통제시스템이 구축되지 않은 각 기관의 장은 온라인 유지보수를 즉시 실시하지 않고서는 기관 업무수행에 현저한 저해가 있다고 예상되는 경우에는 공개등급

정보시스템(인터넷망 정보시스템을 포함한다)에 한하여 직접 접속하는 온라인 유지보수를 일시적으로 허용할 수 있다.

③ 기타 정보시스템 온라인 유지보수 보안과 관련한 사항은 제24조를 준용한다.

④ 제1항에도 불구하고 「재난 및 안전관리 기본법」 및 「감염병의 예방 및 관리에 관한 법률」 등에 따른 국가 재난 또는 위기 상황에 해당하는 경우 각 기관의 장은 국가정보원장의 보안성 검토를 통해 국가정보원장과 협의하여 유지보수를 허용할 수 있다.

제47조의2(통합인증체계) 제76조의2에 따라 구축·운영하는 통합인증체계는 국가정보원장이 안전성을 검증한 제품을 도입하거나, 다음 각 호의 기술적 보안 요건을 준수해야 한다.

1. SAML, OAuth, OIDC 등 국제적으로 검증된 인증·권한부여 표준 사용
2. 인증토큰 및 사용자 정보 전송시에는 TLS 1.2 이상의 암호화 통신 구간을 형성
3. 인증 세션의 유효기간을 설정하고, 일정 시간 활동이 없는 경우 세션 자동 종료(Timeout)
4. 인증 서버와 연계시스템 간 상호 신뢰 검증 및 세션 무결성 확보
5. 인증·접근 이력에 대한 상시 모니터링을 통해 이상행위를 탐지하고, 수준에 따라 경고·추가인증·접근제한·차단 등 단계적 대응

6. 인증・접근 이력(로그인 성공・실패 여부, 접속 IP, 시간 등을 포함)에 대한 로그는 1년 이상 보관

제48조(서버 보안) ① 각 기관의 장은 서버를 도입・운용하고자 할 경우 사이버공격・위협으로 인한 자료 절취 및 위・변조 등에 대비하여 다음 각 호의 사항을 포함한 보안대책을 수립・시행하여야 한다.

1. 서버 내 저장자료에 대하여 업무별・자료별 중요도에 따라 개별사용자의 접근권한 차등 부여
2. 개별사용자별 자료 접근범위를 서버에 등록하여 인가여부를 식별하도록 하고 인가된 범위 이외의 자료 접근통제
3. 서버 운용에 필요한 서비스 포트 이외에 불필요한 서비스 포트 제거 및 관리자용 서비스와 개별사용자용 서비스 분리・운용
4. 관리자용 서비스 접속시 특정 IP주소가 부여된 관리용 단말기 지정・운용
5. 서버 설정 정보 및 저장자료에 대한 정기적 백업 실시
6. 데이터베이스에 대하여는 개별사용자의 직접 접속 차단, 개인정보 등 중요정보 암호화 등 데이터베이스별 보안조치 실시
7. 컴퓨터 운영체제・소프트웨어의 취약점 및 버전 업데이트 여부를 정기적으로 점검하고 최신 버전으로 유지

② 서버 관리자는 제1항에 따른 보안대책의 적절성을 수시 확인하여야 하며 연1회 이상 서버 설정 정보와 저장자료의 절취 및 위・변조 가능성 등 보안취약점을 점검・보완하여야 한다.

제49조(공개서버 보안) ① 각 기관의 장은 외부인에게 공개할 목적으로 웹서버 등 공개서버를 구축·운용하고자 할 경우 공개등급 도메인에 설치하여야 한다.

② 각 기관의 장은 비(非)인가자의 공개서버 저장자료 절취 및 위·변조, 분산서비스거부(DDoS) 공격 등에 대비하여 침입차단·탐지시스템 및 DDoS 대응장비 설치 등 보안대책을 수립·시행하여야 한다.

③ 공개서버 관리자는 비(非)인가자의 공개서버 내 비공개 정보에 대한 무단 접근을 방지하기 위하여 서버에 접근할 수 있는 개별사용자를 제한하고 불필요한 계정은 삭제하여야 한다.

④ 공개서버 관리자는 공개서버 서비스에 필요한 프로그램을 개발·시험하기 위하여 사용한 도구(컴파일러 등) 및 서비스와 관계가 없는 산출물은 개발 완료 후 삭제하여야 한다.

⑤ 기타 공개서버 보안과 관련한 사항은 제48조를 준용한다.

⑥ 각 기관의 장은 공공 웹사이트를 구축·운영하는 경우, 이용자의 접속 단말에 플러그인 소프트웨어 설치를 강제하거나 유도하는 방식을 최소화하여야 한다.

제50조(로그기록 유지) ① 각 기관의 장은 정보시스템의 효율적인 통제·관리 및 사고 발생 시 추적 등을 위하여 로그기록을 유지·관리하여야 한다.

② 제1항에 따른 로그기록에는 다음 각 호의 사항이 포함되어야 한다.

1. 접속자, 정보시스템·응용프로그램 등 접속대상
2. 로그온·오프, 자료의 열람·출력 등 작업 종류 및 시간

3. 접속 성공・실패 등 작업 결과

4. 전자우편 사용 등 외부발송 정보 등

③ 정보시스템 관리자는 로그기록을 생성하는 정보시스템의 경우 시간 동기화 프로토콜(NTP) 적용 등을 통해 정확한 기록을 유지하여야 한다.

④ 정보시스템 관리자는 로그기록을 정기적으로 점검하고 점검 결과 비(非)인가자의 접속 시도, 자료의 위・변조 및 삭제 등 의심스러운 정황이나 위반한 사실을 발견한 경우 즉시 사이버보안담당관에게 통보하여야 한다.

⑤ 정보시스템 관리자는 로그기록을 1년 이상 보관하여야 하며 로그기록의 위・변조 및 외부유출 방지대책을 수립・시행하여야 한다.

⑥ 정보시스템 관리자는 제5항에 따라 보관되는 로그기록의 유출을 방지하기 위한 백업체계를 구축하는 등 대책을 마련하여야 한다.

제51조(업무용 통신단말기 보안) ① 각 기관의 장은 업무용 통신단말기를 이용하여 업무자료 등 중요정보를 소통・관리하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립・시행하여야 한다.

1. 통신단말기에 대한 장치 및 개별사용자 인증

2. 제어신호 및 통화내용 등 데이터 암호화

3. 분실・탈취・훼손 등에 대비한 관리적・물리적・기술적 보안대책

② 각 기관의 장은 제1항에 따른 보안대책을 수립하기 위하여 국가정보원장에게 취약점 점검 및 기술 지원을 요청할 수 있다.

③ 각 기관의 장은 제1항제1호에 따른 통신단말기 개별사용자를 대상

으로 인증 및 암호화에 필요한 디지털정보를 발급할 수 없을 경우 국가정보원장이 배포한「정보통신기기 암호기술 적용지침」을 준수하여야 한다.

④ 각 기관의 장은 해당 기관의 주요 보직자가 안전한 통화를 위하여 사용하는 공용(公用) 휴대폰(이하 "안보폰"이라 한다)이 분실·훼손되지 않도록 현황을 관리하여야 한다. 이 경우 각 기관의 장은 국가정보원장이 예외로 허용하는 운용방식 이외에는「보안업무규정 시행규칙」에 따라 보안대책을 수립·시행하여야 한다.

제52조(모바일 업무 보안) ① 각 기관의 장은 휴대폰·태블릿 PC 등을 이용한 모바일 업무환경(내부 행정업무, 현장 행정업무 및 대민서비스 업무 등)을 구축·운용하고자 할 경우 보안대책을 수립·시행하여야 한다.

② 기타 모바일 업무 보안과 관련한 사항은 국가정보원장이 배포한「국가·공공기관 모바일 활용업무에 대한 보안가이드라인」을 준수하여야 한다.

제53조(사물인터넷 보안) ① 각 기관의 장은 사물인터넷을 이용한 시스템을 구축·운용하고자 할 경우 사물인터넷 기기 및 중요 데이터 등을 보호하기 위하여 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 사물인터넷을 이용한 시스템을 구축·운용하고자 할 경우 공개등급 정보시스템 및 일반사무 목적의 기밀등급·민감등급 정보시스템으로부터 접속할 수 없도록 분리하여야 한다. 다만, 기밀등급·민감등급 정보시스템과 통신이 필요한 경우에는 CDS를 활용

한 보안대책을 수립하여야 한다.

③ 각 기관의 장은 사물인터넷 서비스를 위한 소프트웨어를 개발할 경우 제25조를 준수하여야 한다.

④ 기타 사물인터넷 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 사물인터넷(IoT) 보안가이드라인」을 준수하여야 한다.

제54조(원격근무 보안) ① 각 기관의 장은 소속 공무원등이 재택근무, 출장지 현장 근무, 또는 파견 근무(제44조에 따라 기관 정보통신망 전용(專用) 단말기를 설치 운영하는 경우는 제외한다)시 인터넷을 통해 본인 인증을 거쳐 기관 정보시스템에 접속하여 온라인상으로 수행하는 업무를 수행(이하 "원격근무"라 한다)하게 할 수 있다.

② 제1항에 따른 원격근무를 위해 접속할 수 있는 기관 정보시스템은 다음 각 호의 구분에 따른다.

1. 소속 또는 근무중인 기관의 장이 지급한 '온북' 단말기(「행정기관 온북 도입 가이드(행정안전부)」에 따라 언제 어디서나 사무실과 동일한 환경으로 업무와 인터넷 등을 사용할 수 있는 보안성이 강화된 업무용 노트북을 말한다. 이하 같다.) 또는 국가정보원장이 보안성을 확인한 단말기: 공개등급 정보시스템 및 민감등급 정보시스템에 직접 접속
2. 개인단말기: 다음 각 목에 따른 시스템
   가. 공개등급 업무정보 처리가 가능한 가상 PC 또는 이에 준하는 정보서비스

나. 제39조의5에 따른 방법을 통해 민감등급 업무정보 처리가 가능한 가상 PC 또는 이에 준하는 정보서비스

③ 제1항에 따른 원격근무로 취급할 수 있는 업무정보의 범위는 공개등급 또는 민감등급 업무정보로 한다.

④ 각 기관의 장은 원격근무를 시행하고자 할 경우 다음 각 호의 사항을 포함한 보안대책이 강구된 정보시스템(이하 "원격근무시스템"이라 한다)을 구축·운영하여야 한다.

1. 검증필 암호모듈이 탑재된 정보보호시스템을 사용해 원격근무시스템과 원격근무자의 단말기 간 소통구간 암호화
2. 문서 암호화제품(DRM) 사용 등 문서 보호대책 강구
3. 원격근무자를 식별·인증하기 위하여 소유기반 인증(모바일신분증, OTP, SMS 등) 및 생체기반 인증(지문·홍채인식 등) 등 서로 다른 인증방식을 다중 적용
4. 원격근무자로 하여금 원격근무시스템 접속과정에서 제1호부터 제3호까지의 보안대책을 준수토록 조치
5. 원격근무시스템에 대한 보안취약점 정기 점검

⑤ 원격근무자는 각 기관의 장 등이 원격근무용 단말기(개인 소유의 정보통신기기를 포함한다)의 보안을 위하여 취하는 다음 각 호의 조치에 적극 협조하여야 한다.

1. 제4항에 따라 각 기관의 장이 제공하는 보안소프트웨어 설치·운영
2. 사이버공격·위협 등으로 인한 자료유출 사고 발생 시 각 기관의 장이 요청하는 점검 및 제86조제3항에 따른 자료제출 요청 협력

⑥ 각 기관의 장은 원격근무자에게 제5항에 따른 보안조치 등이 포함된 보안서약서를 징구하고 직위·임무에 부합한 정보시스템 접근권한 부여 및 보직변경·퇴직 등 변동사항이 발생시 접근권한 조정 등의 절차를 마련·시행하여야 한다.

⑦ 기타 원격근무 보안과 관련한 사항은 국가정보원장이 배포한 「원격업무 통합보안매뉴얼」을 준수하여야 한다.

제55조(국제회의 보안) ① 각 기관의 장은 국제협상 등 중요 국제회의를 위하여 PC·노트북 등 정보시스템을 국외 현지에서 설치·운용하고자 할 경우 관련 정보·자료가 유출되지 아니하도록 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 설치장소에 대한 물리적 접근통제
2. 정보시스템 접근 통제 및 분실 방지 등 보안관리
3. 정보시스템 저장자료 암호화 등 자료 접근통제
4. 전화기·팩스 등 통신장비에 대한 도청방지

② 국제회의 참가자는 회의 상대방이 제공한 PC·노트북·휴대용 저장매체 등 정보시스템을 사용하여서는 아니 된다.

제56조(저장매체 불용처리) ① 각 기관의 장은 정보시스템 또는 저장매체(하드디스크·반도체 기반 저장장치(SSD) 등)를 외부수리·교체·반납·양여·폐기·불용 처리하고자 할 경우 정보시스템 및 저장매체에 저장된 자료가 외부에 유출되지 않도록 자료 삭제 등 보안조치를 실시하여야 한다. 이 경우 정보시스템 관리자 및 개별사용자는 분임사이버보안담당관과 협의하여야 한다.

② 제1항에 따라 자료를 삭제할 경우 해당 기관의 실정에 맞게 저장매체별·자료별 차별화된 삭제 방법을 적용할 수 있다.

③ 비밀·대외비를 저장하거나 암호화 키를 저장한 저장매체는 소각·파쇄·용해 등의 방법으로 완전 파괴하여야 한다.

④ 기타 정보시스템 및 저장매체의 불용처리와 관련한 사항은 국가정보원장이 배포한 「정보시스템 저장매체 불용처리지침」을 준수하여야 한다.

제3절 자료 보안

제57조(기밀·민감등급 업무정보 처리) ① 공무원등은 기밀(비밀을 제외한다)·민감등급 업무정보를 다음 각 호의 어느 하나에 해당하는 방법으로만 처리하여야 한다.

1. 소속 또는 근무중인 기관의 기밀(비밀을 제외한다)·민감등급 정보시스템에 작성 및 저장·보관
2. 소속 또는 근무중인 기관의 장이 지급한 휴대용 저장매체에 작성 및 저장·보관
3. 다음 각 목의 어느 하나에 해당하는 수단(이하 "업무자료 공식 소통수단" 이라 한다)을 이용한 수·발신 또는 등재·열람

   가. 소속 또는 근무중인 기관의 장이 자체적으로 구축·운용하는 전자우편시스템(이하 "기관 전자우편"이라 한다)

   나. 공무원등이 공동으로 사용할 목적으로 문화체육관광부장관이 구축·운용하는 전자우편시스템(이하 "공직자통합메일"이라 한

다)

다. 공무원등이 다른 공무원등과 자료를 공유하거나 소통하기 위하여 사용하는 전용(專用) 소프트웨어(이하 "공공 전용(專用) 메신저"라 한다)

라. 국회사무처가 구축·운용하는 의정자료전자유통시스템 등 기관간 업무자료의 소통 또는 공동활용을 위해 구축한 정보시스템

4. 그 밖에 다른 법규에 따라 허용되는 처리방법

② 공무원등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하는 경우 소속 또는 근무중인 기관의 장이 지급한 인터넷 PC 또는 출장용 노트북을 이용하여 기밀(비밀을 제외한다)·민감등급 업무정보를 처리할 수 있다.

1. 업무자료 공식 소통수단의 발신 또는 등재 기능을 이용하여 제2조제13호다목의 문장 또는 문구 작성

2. 업무자료 공식 소통수단으로 수·발신 또는 등재·열람하는 과정에서의 일시적 저장

3. 다음 각 목의 보안대책이 구비된 인터넷 PC에 작성·저장

가. 정보시스템 및 개별사용자 PC 영역 등에 대한 접근 통제 대책

나. 인터넷 PC의 악성코드 감염 최소화를 위한 인터넷 사용 통제대책

다. 인터넷 PC의 악성코드 감염에 따른 기밀·민감등급 정보시스템으로의 피해확산 차단 대책

라. 사이버공격·위협 탐지·대응 등 안전한 업무환경을 위한 보호대책

4. 제41조제3항 및 제4항에 따라 영상회의 솔루션을 활용하여 기밀(비밀을 제외한다)·민감등급 업무정보의 화면 영상을 공유하기 위한 일시적 저장

③ 공무원등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하는 경우 개인이 소유한 PC·휴대용 저장매체·휴대폰 등을 이용하여 기밀(비밀을 제외한다)·민감등급 업무정보를 처리할 수 있다.

1. 업무자료 공식 소통수단의 발신 기능 또는 등재 기능을 이용하여 제2조제13호다목의 문장 또는 문구 작성
2. 업무자료 공식 소통수단으로 수·발신 또는 등재·열람 과정에서의 일시적 저장
3. 제54조제4항에 따른 원격근무시스템에 접속하여 작성
4. 「감염병의 예방 및 관리에 관한 법률」 제34조제1항에 따른 감염병 위기관리 조치 등 대규모 질병·재난 발생 등 특별한 사정으로 재택근무를 명받았으나 소속 또는 근무중인 기관에 제54조제4항에 따른 원격근무시스템이 구축되지 아니한 경우
5. 제41조제3항 및 제4항에 따른 영상회의 솔루션을 활용하여 기밀(비밀을 제외한다)·민감등급 업무정보의 화면 영상을 공유하기 위한 일시적 저장
6. 국민의 생명·신체, 국가안보 및 공공의 안전 등을 위하여 긴급히 작성, 저장, 수·발신이 필요하다고 소속 또는 근무중인 기관의 장이 인정하는 경우

④ 공무원등은 제3항제5호 및 제6호에 해당하는 경우를 제외하고는

「정보통신망 이용촉진 및 정보보호 등에 관한 법률」제2조제1항제2호에 따른 정보통신서비스(전자우편·메신저 등을 포함한다) 및 인공지능을 활용한 상용 정보통신서비스 또는 국외에서 제공하는 이와 유사한 서비스(이하 "상용 정보통신서비스"라 한다)를 이용하여 기밀(비밀을 제외한다)·민감등급 업무정보를 작성, 저장, 수·발신하여서는 아니 된다.

⑤ 공무원등은 제2항부터 제4항까지에 따라 작성·저장한 기밀(비밀을 제외한다)·민감등급 업무정보는 활용이 종료된 후에는 삭제하여야 한다.

제57조의2(특정 상황별 기밀·민감등급 업무정보 처리) ① 모든 공무원등은「국회법」제128조제2항,「국정감사 및 조사에 관한 법률」 제10조제2항, 「국회증언감정법」제2조 및 제4조에 따라 국회·정부간 기밀(비밀을 제외한다)·민감등급 업무정보를 소통할 경우에는 우선적으로 제57조제1항제3호라목의 의정자료전자유통시스템을 활용하여 처리하여야 하며, 시스템 장애 등 부득이한 사유로 활용이 곤란할 경우에 한해 제57조에 허용된 다른 방법으로 처리할 수 있다.

② 감독·감사·조사 등의 관계 법령에 따라 기밀(비밀을 제외한다)·민감등급 업무정보를 제출받을 권한이 있는 공무원등은 업무자료를 제출할 상대방 공무원등에게 제57조에 위반되는 방법으로 자료 제출을 요구하여서는 아니 된다.

③ 공무원등이 자문 등의 목적으로 기밀(비밀을 제외한다)·민감등급 업무정보를 업무자료 공식 소통수단을 활용할 수 없는 민간인에게 발

신하거나 민간인으로부터 수신 받고자 할 경우에는 공무원등의 소속 기관 전자우편 또는 공직자 통합메일을 활용해 발신하거나 수신 받아야 한다.

제57조의3(행정전자서명 인증서 등 관리) ① 공무원등은 기밀(비밀을 제외한다)·민감등급 업무정보를 처리하기 위하여 「전자정부법」 제29조에 따른 행정전자서명의 인증서(이하 "행정전자서명 인증서"라 한다)를 인터넷 PC 또는 개인이 소유한 PC·휴대용 저장매체·휴대폰 등에 저장·보관할 수 있다.

② 공무원등은 행정전자서명 인증서 및 인증서의 비밀번호, 기관 전자우편 또는 공직자통합메일의 비밀번호 등을 상용 정보통신서비스를 이용하여 수·발신하거나 저장·보관하여서는 아니 된다.

제58조(기밀·민감등급 업무정보 유출방지) ① 각 기관의 장은 제57조에 따른 기밀(비밀을 제외한다)·민감등급 업무정보 처리 절차 준수여부를 관리·통제할 수 있는 보안체계를 구축·운영하여야 하며, 검증필 암호모듈 등을 사용하여 기밀(비밀을 제외한다)·민감등급 업무정보의 위조·변조·훼손 및 유출 등을 방지하기 위한 보안대책을 강구하여야 한다.

② 각 기관의 장은 소속 공무원등이 공공 전용(專用) 메신저 이용을 활성화할 수 있도록 노력하여야 한다.

제58조의2(비밀의 전자적 처리) ① 각 기관의 장은「보안업무규정」에 따라 비밀의 생산, 분류, 보관, 열람, 출력, 송·수신, 이관, 파기 등을 전자적으로 처리할 수 있다.

② 각 기관의 장은 비밀을 전자적으로 처리하는 전(全) 과정에서 기밀성, 무결성, 인증, 부인방지 등 보안성을 확보하여야 하며 이를 위하여 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 사용하여야 한다.

③ 제1항에 따라 비밀을 전자적으로 처리할 경우 제36조의4제2항에 따라 서로 다른 등급의 도메인 또는 정보시스템을 분리한 기관은 분리된 기밀등급 영역에서 처리할 수 있으며 그 밖의 기관은 인터넷망과 분리된 별도의 기밀등급 정보시스템에서 처리하여야 한다.

④ 종이문서로 출력된 비밀의 관리에 관하여는 「보안업무규정」을 준수하여야 한다.

제58조의3(비밀관리시스템 운용) 각 기관의 장은 국가정보원장이 개발하여 보급한 통합 비밀관리시스템을 도입·운영할 수 있다.

제58조의4(대외비의 전자적 처리) ① 각 기관의 장은 대외비를 전자적으로 처리하고자 할 경우에는 검증필 암호모듈을 사용하여 위조·변조·훼손 및 유출 등을 방지하기 위한 보안대책을 강구하여야 하며, 보호기간이 만료된 대외비는 제57조에 따른 기밀(비밀을 제외한다)·민감등급 업무정보의 처리 기준을 적용하여야 한다.

② 각 기관의 장은 업무와 관계되지 아니한 사람이 대외비를 열람, 복제·복사, 배부할 수 없도록 보안대책을 수립·시행하여야 한다.

제59조(공개등급 업무정보 처리) 공무원등은 관계 법규에 위배되지 않는 범위 내에서 인터넷 PC나 개인이 소유한 PC·휴대용 저장매체·휴대폰(기관 청사내에서는 제69조제1항 각 호에 따라 반입한 경우를

말한다), 상용 정보통신서비스(기관 청사내에서는 제43조제2항에 따른 제한이 없는 경우를 말한다) 등을 이용하여 공개등급 업무정보를 처리할 수 있다.

제60조(홈페이지 등 게시자료 보안) ① 부서 분임사이버보안담당관은 해당 부서에서 홈페이지 등에 업무자료를 게시하고자 할 경우 자료 내용을 사전 검토하여 비공개 업무자료가 게시되지 아니하도록 하여야 한다.

② 부서 분임사이버보안담당관은 소속 부서에서 운용하는 홈페이지에서 기밀·민감등급 업무정보가 무단 게시되었는지 여부를 정기적으로 점검하여야 한다.

③ 각 기관의 장은 홈페이지 등에 기밀·민감등급 업무정보가 무단 게시된 사실을 인지한 경우 즉시 삭제 또는 차단 등 보안조치를 취하여야 한다.

④ 그 밖에 홈페이지 자료 등록 등 운영·관리는「성평등가족부 홈페이지 운영 및 관리 지침」을 준수하여야 한다.

제61조(정보통신망 현황자료 관리) ① 각 기관의 장은 다음 각 호에 해당하는 자료를「공공기관의 정보공개에 관한 법률」제9조제1항에 따른 비공개 대상 정보로 지정·관리하여야 한다.

1. 정보통신망 구성현황(IP주소 할당현황을 포함한다. 이하 본 조에서 같다)
2. 정보시스템 운용현황
3. 취약점 분석·평가 결과물(「정보통신기반 보호법」제9조에 따른 취약점 분석·평가결과를 포함한다. 이하 본 조에서 같다))

4. 주요 정보화사업 추진현황

② 각 기관의 장은 제1항에도 불구하고 다른 기관과 협력하여 정보통신망 및 정보시스템 운용 또는 사이버보안업무를 수행할 필요가 있는 경우 제1항 각 호에 해당하는 자료를 다른 기관의 장에게 제공할 수 있다.

제62조(빅데이터 보안) ① 각 기관의 장은 빅데이터와 관련한 시스템을 구축·운용하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1.데이터의 수집 출처 확인 및 데이터 오·남용 방지

2.데이터 수집을 위한 정보통신망 보안체계 수립

3. 수집된 데이터의 저장 및 보호체계 수립

4. 중요 데이터 암호화

5. 사용자별(데이터 제공자·수집자·분석요청자 및 분석결과 제공자 등) 권한부여 체계 수립

6. 데이터 파기절차 수립

② 그 밖에 빅데이터 보안과 관련한 사항은 개인정보보호위원회가 고시한「개인정보의 안전성 확보조치 기준」 및 국가정보원장이 배포한「국가·공공기관 빅데이터 보안 가이드라인」을 준수하여야 한다.

제62조의2(인공지능시스템 보안) ① 각 기관의 장은 인공지능시스템을 구축·운용하고자 할 경우 보안대책을 수립·시행하여야 한다.

② 제1항에 따른 보안대책 수립·시행 시 국가정보원장이 배포한 「AI 보안 가이드북」 등 AI 보안 관련 가이드라인을 활용하도록 노력하

여야 한다.

제4절 사용자 보안

제63조(개별사용자 보안) ① 각 기관의 장은 소관 정보통신망 또는 정보시스템의 사용과 관련하여 다음 각 호의 사항을 포함한 개별사용자 보안에 관한 절차 및 방법을 마련하여야 한다.

1. 직위·임무별 정보통신망 접근권한 부여 심사
2. 비밀 등 중요자료 취급시 비밀취급 인가, 보안서약서 징구 등 보안조치
3. 보직변경, 퇴직 등 변동사항 발생시 정보시스템 접근권한 조정

② 공무원등은 본인이 PC 등 정보시스템을 사용하거나 정보통신망에 접속하는 행위와 관련하여 스스로 보안책임을 진다.

제64조(단말기 보안) ① 개별사용자는 소속된 기관에서 지급받은 PC·노트북·휴대폰·스마트폰·태블릿·온북 등 단말기(이하 "단말기"라 한다) 사용과 관련한 일체의 보안관리 책임을 진다.

② 개별사용자는 단말기에 대하여 다음 각 호에 해당하는 보안대책을 준수하여야 한다.

1. CMOS·로그온 비밀번호 설정
2. 단말기 작업을 일정 시간 중단시 비밀번호 등을 적용한 화면보호조치
3. 최신 백신 소프트웨어 설치
4. 운영체제 및 응용프로그램에 대한 최신 버전 및 보안패치 유지

5. 출처, 유통경로 및 제작자가 불분명한 응용프로그램의 사용 금지

6. 인터넷을 통해 자료(파일) 획득시 신뢰할 수 있는 인터넷사이트를 활용하고 자료(파일) 다운로드시 최신 백신 소프트웨어로 검사 후 활용

7. 승인되지 않은 인터넷 파일공유·메신저·대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 및 공유 폴더 삭제

8. 웹브라우저를 통해 서명되지 않은 프로그램이 실행되지 않도록 보안 설정

9. <삭제>

②의 2. 공개등급 정보시스템에 속하는 단말기(기관 인터넷망 등 인터넷 접속이 가능한 단말기를 포함한다)에서 제36조의4제1항에 따른 보안대책을 적용하는 경우에 한해 문서편집 프로그램 설치 및 자료 작성할 수 있다.

③ 부서 분임사이버보안담당관은 사이버보안담당관 총괄 하에 개별사용자의 제2항 각 호 및 제2항 2에 해당하는 보안대책의 준수여부를 정기적으로 점검하고 개선 조치하여야 한다.

제65조(계정 관리) ① 각 기관의 장은 개별사용자에게 소관 정보통신망 또는 정보시스템의 접속에 필요한 사용자별 계정(아이디)을 부여하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 개별사용자별 또는 그룹별 접근권한 부여

2. 외부인에게 계정을 부여하지 아니하되 업무상 불가피한 경우 기관의 장 책임 하에 보안조치 후 필요한 업무에 한하여 일정기간 동안

접속 허용

3. 특별한 사유가 없는 한 용역업체 인원에게 관리자 계정 부여 금지

4. 비밀번호 등 식별 및 인증 수단이 없는 사용자 계정은 사용 금지

② 정보시스템 관리자는 개별사용자가 시스템 접속(로그온)에 5회 이상 실패할 경우, 해당 계정을 잠근 후 다음 각 호 중 어느 하나의 대응조치를 시행하고 비(非)인가자의 침입여부를 점검하여야 한다.

1. 관리자가 설정한 시간 경과 후 잠금 해제

2. 추가적인 식별 및 인증수단을 통한 추가인증 후 잠금 해제

③ 정보시스템 관리자는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 부여된 접근권한을 회수하여야 한다.

④ 정보시스템 관리자는 사용자 계정 부여 및 관리의 적절성을 연2회 이상 점검하고 그 결과를 사이버보안담당관에게 통보하여야 한다.

⑤ 정보시스템 관리자는 제1항 및 제3항에 의한 접근권한 부여, 변경, 회수 또는 삭제 등에 대한 내역을 기록하고 3년 이상 보관하여야 한다.

제66조(비밀번호 관리) ① 개별사용자 및 정보시스템 관리자는 각종 비밀번호를 다음 각 호에 해당하는 사항을 반영하고 숫자·문자·특수문자 등을 혼합하여 안전하게 설정하고 정기적으로 변경·사용하여야 한다.

1. 사용자 계정(아이디)과 동일하지 않은 것

2. 개인 신상 및 부서 명칭 등과 관계가 없는 것

3. 일반 사전에 등록된 단어의 사용을 피할 것

4. 동일한 단어 또는 숫자를 반복하여 사용하지 말 것

5. 사용된 비밀번호는 재사용하지 말 것

6. 동일한 비밀번호를 여러 사람이 공유하여 사용하지 말 것

7. 응용프로그램 등을 이용한 자동 비밀번호 입력기능을 사용하지 말 것

8. 키보드 배열상 연속된 문자열(예: qwerty, 12345 등)을 사용하지 말 것

② 정보시스템 관리자는 서버 등 정보시스템에 보관되는 비밀번호가 복호화 되지 아니하도록 일방향 암호화하여 저장하여야 한다.

③ 각 기관의 장은 정보시스템에서 개별사용자의 식별 및 인증을 위하여 비밀번호에 갈음하거나 병행하여 지문인식 등 생체인증 기술 및 일회용 비밀번호 생성기(OTP) 등을 안전성 확인 후 사용할 수 있다. 이 경우 생체인증 정보는 안전하게 보관하여야 한다.

④ 정보시스템의 관리자 권한 인증은 정보통신망 또는 정보시스템의 특성상 불가피한 경우를 제외하고, 다중인증을 적용하여야 한다.

제66조의2(통합인증체계의 구축·운영) 각급기관의 장은 정보시스템의 안전한 접근통제와 사용자 편의성 제고를 위해 제52조의2에 따른 도입요건을 만족하는 방법으로 통합인증체계를 구축·운영할 수 있다.

제67조(전자우편 보안) ① 각 기관의 장은 전자우편을 컴퓨터바이러스·트로이목마 등 악성코드로부터 보호하기 위하여 백신 소프트웨어 설치, 해킹메일 차단시스템 구축 등 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 기관 전자우편을 구축·운용할 경우 다른 전자우편과 자료를 안전하게 소통하기 위하여 전자우편시스템에 검증필 암호

모듈 등의 암호화 기술을 적용하여야 한다.

③ 각 기관의 장은 기관 전자우편을 구축·운용할 경우 수신된 전자우편의 발신지 IP주소 및 국가명이 표시되고 해킹메일로 의심될 경우 해킹메일 원본을 전송하여 신고할 수 있는 기능을 갖추어야 한다.

④ 개별사용자는 수신된 전자우편에 포함된 첨부파일이 자동 실행되지 아니하도록 기능을 설정하고 첨부파일을 다운로드할 경우 최신 백신 소프트웨어로 악성코드 은닉여부를 검사하여야 한다.

⑤ 개별사용자는 출처가 불분명하거나 의심되는 제목의 전자우편은 열람하지 말고 해킹메일로 의심될 경우 즉시 사이버보안담당관에게 신고하여야 한다. 사이버보안담당관은 해킹메일로 판단될 경우 국가정보원장과 성평등가족부장관에게 통보하여야 한다.

⑥ 각 기관의 장은 전자우편 발신자 조작 등을 통한 기관 사칭 전자우편의 유포를 차단하기 위하여 보안대책을 수립·시행하여야 한다.

제68조(휴대용 저장매체 보안) ① 각 기관의 장은 휴대용 저장매체를 사용하여 업무자료를 보관하고자 할 경우 자료의 위·변조, 저장매체의 훼손·분실 등에 대비한 보안대책을 수립·시행하여야 한다.

② 각 기관의 장은 교육현장 등 휴대용 저장매체 통제가 불가능한 환경을 제외하고 휴대용 저장매체 관리시스템을 구축·운영하여야 하며, 국가정보원장이 안전성을 검증한 제품을 도입하여야 한다. 사이버보안담당관은 이를 활용하여 휴대용 저장매체 현황을 유지하고, 개별사용자의 사용이력 및 이동자료 정보 등에 관한 로그는 최소 1년 이상 보관하여야 한다.

③ 사이버보안담당관은 개별사용자가 휴대용 저장매체를 PC·서버 등에 연결할 경우 자동 실행되지 아니하고 최신 백신 소프트웨어로 악성코드 감염여부를 자동 검사하는 등의 보안 정책을 수립·시행하도록 관리하여야 한다.

④ 휴대용 저장매체 관리자는 휴대용 저장매체를 비밀용·일반용으로 구분·관리하고 수량 및 보관 상태를 정기적으로 점검하며 외부 반출·입을 통제하여야 한다.

⑤ 휴대용 저장매체 관리자는 비밀이 저장된 휴대용 저장매체별에 매체별로 비밀등급 및 관리번호를 부여하고 비밀관리기록부에 등재·관리하여야 한다. 이 경우 매체 전면에 비밀등급 및 관리번호가 표시되도록 하여야 한다.

⑥ 휴대용 저장매체 관리자는 비밀용 휴대용 저장매체를 다른 등급의 비밀용 또는 일반용으로 변경 사용하고자 할 경우 저장자료가 복구 불가하도록 완전삭제 소프트웨어 등을 이용하여 삭제하여야 한다. 다만, 완전삭제가 불가할 경우 변경 사용하여서는 아니 된다.

⑦ 휴대용 저장매체 관리자는 휴대용 저장매체를 폐기·불용 처리하고자 할 경우 저장자료가 복구 불가하도록 완전삭제 소프트웨어 등을 이용하여 삭제하여야 한다. 다만, 완전삭제가 불가할 경우 파쇄하여야 한다.

⑧ 부서 분임사이버보안담당관은 사이버보안담당관 총괄 하에 소속 부서에 대하여 개별사용자의 휴대용 저장매체 무단 반출, 미(未)등록 휴대용 저장매체 사용여부 등 보안관리 실태를 정기적으로 점검하여

야 한다.

⑨ 그 밖에 휴대용 저장매체 보안과 관련한 사항은 [부록 2]「USB메모리 등 휴대용 저장매체 보안관리지침」을 준수하여야 한다.

제69조(비인가 기기 통제) ① 공무원등은 다음 각 호의 경우를 제외하고는 개인 소유의 정보통신기기를 소속된 기관으로 무단 반입·사용하여서는 아니 된다.

1. 보편적 통신 목적의 개인 소유 이동통신단말기(스마트폰·태블릿·스마트워치) : 반입하여 개인 용도로만 사용
2. 제1호를 제외한 정보통신기기 : 제1호에 따른 반입·사용만으로는 보편적 활용 곤란 등 특별한 사정이 있는 경우에 한하여 소속 부서의 분임사이버보안담당관을 거쳐 사이버보안담당관의 승인을 받아 반입 후 개인 용도로만 사용

② 공무원등은 제1항 각 호에 따라 반입한 개인 소유의 정보통신기기를 소속된 기관의 도메인 등급을 불문하고 기관 정보통신망(제39조제1항제1호에 따른 무선랜 형태를 포함한다)에 연결하여서는 아니 되며, 등급을 불문하고 기관 정보시스템을 다른 정보통신망에 연결하는 수단으로 사용하여서는 아니 된다. 부서 분임사이버보안담당관은 이에 대하여 수시로 점검하여야 한다.

③ 사이버보안담당관은 개인 소유의 정보통신기기가 기관 정보시스템 또는 기관 정보통신망 연결시 자동 차단되도록 조치하고, 업무자료를 외부로 유출하는데 악용될 수 있거나 소속된 기관의 정보통신망 운영에 위해(危害)가 된다고 판단될 경우 반출·입 통제, 보안 소프트웨어

의 설치 조건부 반입 등 보안대책을 수립·시행하여야 한다.

제69조의2(위규자 처리) 각 기관의 장은 「국가공무원 복무·징계 관련 예규」(인사혁신처 중 "비밀 엄수의 의무 위반 처리" 부분 및 국가정보원이 배포한 「정보보안 사고(위규) 처리기준(안)」을 참고하여 사이버보안 위규자에 대한 처리기준을 마련하여야 한다.

제4장 융합 보안

제1절 정보통신시설 및 기기 보호

제70조(정보통신시설 보호대책) ① 각 기관의 장은 다음 각 호의 어느 하나에 해당하는 정보통신시설 및 장소를「보안업무규정」제34조에 따른 보호지역으로 지정·관리하여야 한다.

1. 암호실·정보통신실
2. 통합데이터센터
3. 암호자재 개발·설치 및 정비 장소
4. 국가비상통신 등 중요통신망의 교환국, 회선집중국 또는 중계국
5. 보안관제센터, 백업센터 및 중요 정보통신시설을 집중 제어하는 국소
6. 그 밖에 보안관리가 필요하다고 인정되는 정보시스템 설치장소

② 각 기관의 장은 제1항에 따라 보호지역으로 지정된 정보통신시설 및 장소에 대한 보안대책을 수립하고자 할 경우 다음 각 호에 해당하는 사항을 포함하여야 한다.

1. 방재대책 및 외부로부터의 위해(危害) 방지대책
2. 상시 이용하는 출입문은 한 곳으로 정하고 이중 잠금장치 설치

3. 출입자 식별·인증 등을 위한 출입문 보안장치 설치 및 주·야간 감시대책

4. 휴대용 저장매체를 보관할 수 있는 용기 비치

5. 정보시스템의 안전지출 및 긴급파기 계획 수립

6. 관리책임자 및 자료·장비별 취급자 지정·운영

7. 정전에 대비한 비상전원 공급 및 시스템의 안정적 중단 등 전력관리 대책

8. 비상조명 장치 등 비상탈출 대책

9. 카메라 장착 휴대폰 등을 이용한 불법 촬영 방지대책

③ 여러 기관의 정보자원을 통합·운영하는 기관의 장은 해당 기관의 보안요구사항을 반영하여 보안대책을 수립한 후 이를 국가정보원장 및 성평등가족부장관과 협의하여 시행하여야 한다.

제71조(정보통신시설 출입관리) ① 각 기관의 장은 외부인이 정보통신시설을 방문할 경우 반드시 신원을 확인하고 보안교육 및 보안검색 후 출입을 허용하여야 한다.

② 각 기관의 장은 불가피한 경우를 제외하고는 정보통신시설에 대한 관람 및 견학은 지양하고 외국인의 출입은 금지한다. 다만, 외국인의 출입이 꼭 필요한 경우 국가정보원장과 사전 협의하여 출입을 허용할 수 있다.

③ 삭제

제72조(영상정보처리기기 보안) ① 각 기관의 장은 업무상 목적으로 불특정 사람 또는 사물을 촬영한 영상을 유·무선 정보통신망으로 전송

・저장・분석하는 CCTV・IP카메라・이동형 영상촬영장비・중계서버・관제서버・관리용 PC 등의 기기・장비(이하 "영상정보처리기기"이라 한다)를 설치・운용하고자 할 경우 운영자의 계정・비밀번호 설정 등 인증대책을 수립하고 특정 IP주소에서만 접속 허용 등 비(非)인가자 접근 통제대책을 수립・시행하여야 한다.

② 각 기관의 장은 영상정보처리기기를 통합・운용하는 시설(이하 "영상관제상황실"이라 한다)을 운영하고자 할 경우 영상관제상황실을 「보안업무규정」 제34조제2항에 따른 제한구역 또는 통제구역으로 지정・관리하고 출입통제 장치를 운용하여야 한다.

③ 영상정보처리기기 관리자는 영상정보처리기기를 민감등급 또는 기밀등급 정보시스템으로 분류하여야 한다. 다만, 부득이하게 공개등급 정보시스템과 연결・사용하여야 할 경우 전송내용을 암호화 및 접근통제 등 보안대책을 강구하여야 한다.

④ 영상정보처리기기 관리자는 제1항부터 제3항까지와 관련한 보안대책의 적절성을 수시 점검・보완하여야 한다.

⑤ 기타 영상정보처리기기 보안과 관련한 사항은 국가정보원장이 배포한 「국가 공공기관 영상정보 처리기기 도입・운영 가이드라인」 및 「안전한 정보통신 환경 구현을 위한 네트워크 구축 가이드라인」을 준수하여야 한다.

제73조(RFID 보안) ① 각 기관의 장은 RFID시스템(대상이 되는 사물 등에 RFID 태그를 부착하고 전파를 사용하여 해당 사물 등의 식별정보 및 주변 환경정보를 인식하여 각 사물 등의 정보를 수집・저장・가

공 및 활용하는 시스템을 말한다)을 구축하여 중요정보를 소통하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. RFID시스템(태그 및 리더기를 포함한다) 분실·탈취 대비 및 백업 대책
2. 태그정보 최소화 대책
3. 장치 및 운용자 인증, 중요정보 암호화 대책

② RFID시스템 관리자는 제1항과 관련한 보안대책의 적절성을 수시 점검·보완하여야 한다.

③ 기타 RFID 보안과 관련한 사항은 국가정보원장이 배포한「RFID 보안관리 실무매뉴얼」을 준수하여야 한다.

제74조(디지털복합기 보안) ① 각 기관의 장은 디지털복합기(디지털복사기 등도 포함한다. 이하 "복합기"라 한다)를 설치·운용하고자 할 경우 복합기 내 저장매체가 있거나 장착이 가능한 경우 자료유출을 방지하기 위하여 자료 완전삭제 또는 디스크 암호화 기능이 탑재된 복합기를 도입하여야 한다.

② 복합기 관리자는 제1항에 따라 복합기를 설치·운용할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 암호화 저장 기능이 있는 경우 해당 기능 사용
2. 정기적으로 저장된 작업 내용(출력·스캔 등) 완전 삭제
3. 공유 저장소 사용 제한 및 접근 제어
4. 고정 IP주소 설정 및 불필요한 서비스 제거 또는 비활성화 및 디폴트 계정·비밀번호 변경

③ 복합기 관리자는 다음 각 호의 어느 하나에 해당하는 경우 복합기의 저장매체에 저장된 자료를 완전 삭제하여야 한다.

1. 복합기 사용연한이 경과하여 폐기·양여할 경우
2. 복합기 무상 보증기간 중 저장매체 또는 복합기 전체를 교체할 경우
3. 고장 수리를 위한 외부 반출 등의 사유로 해당 기관이 복합기의 저장매체를 통제 관리할 수 없는 장소로 이동할 경우
4. 그 밖에 저장자료의 삭제가 필요하다고 판단되는 경우

④ 복합기 관리자는 소모품 교체 등 복합기 유지보수를 할 경우 부서 분임사이버보안담당관의 입회·감독 하에 실시하고 저장매체의 무단 교체 등을 예방하여야 한다.

⑤ 복합기 관리자는 복합기를 통해 기밀·민감·공개등급 도메인간 접점이 발생하지 않도록 보안대책을 수립·시행하여야 한다.

⑥ 사이버보안담당관은 소속된 기관의 저장매체가 장착되어 있는 복합기 운용과 관련한 보안대책의 적절성을 수시 점검·보완하여야 한다.

⑦ 기타 복합기 보안과 관련한 사항은 [부록 3]「정보시스템 저장매체 불용처리지침」을 준수하여야 한다.

제75조(재해 복구체계) ① 각 기관의 장은 인위적 또는 자연적인 원인으로 인한 정보통신망의 장애 발생에 대비하여 「전자정부법 제56조의2」에 따른 정보시스템의 백업·소산·이중화 및 복구 등 종합적인 재난·장애 방지대책을 수립·시행하여야 한다.

② 각 기관의 장은 재해 복구체계를 정기적으로 시험·검토하고 재난

으로 인해 업무에 지장이 초래될 가능성에 대한 영향평가를 실시하여야 한다.

③ 각 기관의 장은 정보통신망의 장애 발생에 대비하여 정보시스템 백업시설을 확보하고 정기적으로 백업을 실시하여야 한다.

④ 각 기관의 장은 제3항에 따른 백업시설을 구축·운영하고자 할 경우 정보통신실·통합데이터센터와 물리적으로 일정거리 이상 떨어진 안전한 장소에 설치하여야 하며 전력공급원 이중화 등 정보시스템의 가용성을 최대화 할 수 있도록 하여야 한다.

제2절 전자파 보안

제76조(대도청 측정) ① 각 기관의 장은 다음 각 호의 어느 하나에 해당하는 시설·장소에 대하여 각종 수단에 의한 도청으로부터 정보유출을 방지하기 위해 정책 또는 계획 수립 등을 관리적 보안대책, 도청을 예방 또는 탐지·발견할 수 있는 물리적·기술적 보안대책을 수립·시행하여야 한다.

1. 기관 청사(신축, 이전 또는 증축, 개축, 대규모 수선 등)
2. 기관장실, 회의실 등 중요업무 장소
3. 중요회의·회담·협상·행사 장소
4. 기타 대도청 측정이 필요하다고 판단되는 시설·장소·장비

② 각 기관의 장은 제1항에 따른 시설·장소에 대하여 자체 또는「통신비밀보호법」제10조의3에 따른 불법감청설비탐지업자 활용 등을 통해 대도청 측정을 실시하여야 한다. 다만, 다음 각 호에 해당하는 시설

・장소에 대하여는 국가정보원장에게 대도청 측정을 요청할 수 있다.

1. 성평등가족부장관이 관리하는 시설・장소

2. 산하기관의 장이 관리하는 시설・장소 중에서 성평등가족부장관이 국가안보 및 국익 보호를 위하여 필요하다고 판단하는 시설・장소

③ 제2항에 따라 자체 또는 불법감청설비탐지업자 등을 활용하여 측정을 실시한 기관의 장은 측정결과 취약요인이 발견된 경우 그 결과를 성평등가족부장관을 거쳐 국가정보원장에게 통보하여야 하고 기술 지원 및 추가 측정을 요청할 수 있다.

④ 제2항에 따라 국가정보원장이 측정을 실시한 결과 취약요인이 발견된 경우 해당 기관의 장은 개선대책을 수립・시행하여야 한다.

⑤ 각 기관의 장은 대도청 측정 결과를「공공기관의 정보공개에 관한 법률」제9조제1항에 따른 비공개 대상 정보로 지정・관리하여야 한다.

⑥ 기타 대도청 측정과 관련한 사항은 국가정보원장이 배포한「도청탐지・방어활동 가이드라인」을 준수하여야 한다.

제77조(무선통신망 보안) ① 무선통신망(제39조에 따른 무선랜(WiFi)을 제외한다. 이하 본 조에서 같다)을 구축・운영하거나 이동통신망을 이용하여 관련 시스템을 구축・운용하는 기관의 장, 무선국을 관리하는 기관의 장은 다음 각 호의 사항을 포함한 보안대책을 수립・시행하여야 한다.

1. 접경 지역의 경우 무선통신망의 유선화 추진 또는 전파 차단시설 정책 시행

2. 비밀 등 중요자료를 소통하고자 할 경우 국가정보원장이 개발하거나 안전성을 확인한 암호자재 사용

3. 무선국 현황 관리 및 전파월경 등 통신보안 준수

4. 접경지역에 설치된 전파 차단시설 점검

② 제1항에 따른 기관의 장은 연간 전파측정 계획을 수립하여 연1회 이상 전파측정을 실시하여야 한다.

③ 제1항에 따른 기관의 장은 국가정보원장에게 제2항에 따른 연간 전파측정 계획서를 매년 1.25까지 제출하고 측정·점검 후 20일 이내에 [서식 제5호]에 따른 결과보고서를 제출하여야 한다.

제77조의2(고출력 전자파 보안) ① 주요기반시설 관리기관의 장은 소관 주요기반시설을 고출력 전자파(EMP)로부터 안전하게 보호하기 위한 예방·백업·복구 등 물리적·기술적 대책을 포함한 보호대책을 수립·시행할 수 있다.

② 주요기반시설 관리기관의 장은 제1항에 따른 보호대책을 수립하기 위하여 취약점 분석·평가를 실시할 수 있으며 이를 위하여 담당자 지정 또는 전담반을 구성할 수 있다.

③ 주요기반시설 관리기관의 장은 제1항에 따른 보호대책을 수립할 경우 국가정보원장에게 기술 지원을 요청할 수 있다.

제5장 훈련 및 평가

제1절 훈련 및 측정

제78조(사이버보안 훈련) ① 각 기관의 장은 해당 기관의 정보통신망을 대상으로 매년 정기 또는 수시로 사이버보안 훈련을 실시하여야 한다.

② 성평등가족부장관은 국가차원의 사이버위기 발생에 대비하여 산하 기관의 정보통신망을 대상으로 사이버보안 훈련을 실시할 수 있다. 이 경우 성평등가족부장관은 특별한 사유가 없는 한 해당 기관의 장에게 훈련 일정 등을 사전 통보하여야 한다.

③ 성평등가족부장관은 제2항에 따른 훈련결과 개선이 필요하다고 판단하는 경우 해당 기관의 장에게 개선 조치를 요청할 수 있다. 이 경우 해당 기관의 장은 특별한 사유가 없는 한 개선 조치하여야 하며 성평등가족부장관은 그 이행여부를 확인할 수 있다.

제79조(진단·점검 등) ① 각 기관의 장은 「사이버안보 업무규정」 제12조제1항 또는 그 밖의 법규에 따라 자체 진단·점검을 실시할 경우, 다음 각 호를 준수하여야 한다.

1. 정보통신기기, 정보통신망 또는 이와 관련된 정보시스템의 취약 요소를 발굴할 수 있는 전문인력(자체 인력 또는 외부 업체 등) 확보
2. 국가정보원이 「사이버안보 업무규정」 제6조에 따른 정보공유시스템으로 공유하는 보안권고문 및 진단·점검 관련 매뉴얼·가이드라인·체크리스트 등을 활용
3. 기관이 운용중인 시스템의 중요도·시급성 등에 따라 중장기 점검 계획을 수립
4. 위 제1호 내지 제3호에 필요한 관련 예산 등 확보

② 성평등가족부장관은 다음 각 호의 어느 하나에 해당하는 경우 「사

이버안보 업무규정」 제9조제5항에 따라 사이버보안관리 수준측정을 실시할 수 있다. 이 경우 사이버공격·위협행위를 모사(模寫)한 방식으로 취약점을 발굴할 수 있다.

1.「사이버안보 업무규정」 제9조제1항 후단에 따른 보안성 검토 결과의 이행여부 확인 또는 같은 영 제13조제5항에 따른 사이버보안 실태 평가 개선대책 이행여부를 확인하려는 경우

2.「전자정부법」 제56조제3항 및 「공공기록물 관리에 관한 법률 시행령」제5조 등에 따른 보안조치 이행여부를 확인하고자 하는 경우

3.「보안업무규정」제35조에 따른 보안측정을 실시하는 경우

4. 각 기관의 장이 정보통신망에 대한 보안취약점 점검 또는 종합진단이 필요하다고 판단하여 요청하는 경우

5. 그 밖에 성평등가족부장관이 국가안보상 필요하다고 판단하는 경우

③ 성평등가족부장관은 제2항에 따라 사이버 보안관리 수준측정을 실시할 경우 해당 기관의 장에게 측정항목·일정·준비사항·측정 완료 후 조치 등이 포함된 측정 계획을 사전 통보하여야 한다. 다만, 정보통신망의 안전성을 확보하여야 할 긴급한 사유가 발생한 경우 사전 통보를 생략할 수 있다.

④ 성평등가족부장관은 사이버보안관리 수준측정을 실시한 결과 개선이 필요하다고 판단하는 경우 해당 기관의 장에게 개선 조치를 요청할 수 있다. 이 경우 해당 기관의 장은 정당한 사유가 없으면 다음 각호의 사항을 포함한 조치를 취하여야 한다.

1. 기존에 알려지지 않은 새로운 취약점일 경우, 취약점 제거를 위한

관리적・물리적・기술적 조치

2. 해당 보안취약점이 소속 공무원등의 고의 또는 중과실로 인하여 발생한 경우, 해당 공무원등에 대한 징계검토 및 개선 조치의 지시

3. 제2호의 경우 유사 보안위규행위 방지를 위한 소속 공무원등에 대한 교육 실시

⑤ 성평등가족부장관은 제한된 기한내 효과적으로 사이버보안관리 수준측정을 수행하기 위하여 해당 기관의 장에게 정보통신망 구성도 등의 시스템 정보 제공과 측정용 IP에 대한 시스템 접근 권한 등을 요청할 수 있다. 성평등가족부장관은 측정 종료시 제출받은 자료를 반납하여야 한다.

제79조의2(취약 정보통신제품의 긴급 대체) ① 국가정보원장은 제18조에 따른 보안기능이 있는 정보통신제품 중에서 다음 각 호중의 어느 하나에 해당하는 정보통제품을 도입한 각 기관의 장에게 운용중지를 요청할 수 있다.

1. 사이버안보 위해(危害) 국가・단체가 개발・유통에 연계된 경우

2. 취약점으로 인해 사이버보안을 침해할 수 있는 상당하고 명백한 보안위협이 식별되어 시급한 조치가 필요하다고 판단한 경우

② 제1항에 따라 요청을 받은 기관의 장은 지체없이 운용을 중단하고 동일 성능의 정보통신제품을 예산 범위에서 도입하여 대체하여야 한다.

제79조의3(취약 상용 소프트웨어의 시정조치) 각 기관의 장은 보안취약점이 발생한 제품에 대하여는 제22조의2제2항에 따른 계약에 따라 시정조치를 하여야 한다.

제2절 사이버보안 실태 평가

제80조(평가 실시) ① 성평등가족부장관은 산하기관의 사이버보안 추진상황을 확인하기 위하여 사이버보안 실태 평가를 평가 할 수 있다.

② 성평등가족부장관은 제1항에 따라 평가를 실시할 경우 매년 평가지표・절차・시기 등을 정하여 해당 기관의 장에게 통보하여야 한다.

제81조(자체 평가) 산하기관의 장은 제80조 제2항에 따른 성평등가족부장관이 배포한 평가지표에 따라 자체 평가를 실시하고, 자체평가 결과 및 자체 평가의 적절성을 입증할 수 있는 증빙자료를 성평등가족부장관에게 제출하여야 한다.

제82조(현장 실사) ① 성평등가족부장관은 각 기관이 실시한 자체 평가에 대한 객관성・공정성을 확보하기 위하여 해당 기관을 방문하여 자체 평가결과를 검증(이하 "현장 실사"라 한다)할 수 있으며 이 경우 관계 전문가를 참여시킬 수 있다.

② 성평등가족부장관은 현장 실사를 효율적으로 수행하기 위하여 해당 기관의 장에게 자체 평가에 대한 증빙자료 제출, 담당자 면담 등 협조를 요청할 수 있다.

③ 성평등가족부장관은 현장 실사를 할 경우 다음 각 호에 해당하는 사항을 수행할 수 있다.

1. 사이버위기 대응능력 점검
2. 정보통신망 및 정보시스템 사이버보안관리 수준 측정
3. PC 등 단말기・휴대용 저장매체 보안관리 실태 확인

4. 공무원등의 사이버보안 기본수칙 숙지여부 확인

④ 성평등가족부장관은 현장 실사를 종료한 경우 해당 기관이 제출한 자료를 반납하여야 한다. 다만, 필요한 경우 해당 기관의 장 협조 하에 사본 1부를 제출받을 수 있다.

제83조(평가결과 통보) ① 성평등가족부장관은 사이버보안 실태 평가 결과의 적정성 여부를 확인하기 위하여 민·관 전문가를 활용할 수 있다.

② 성평등가족부장관은 평가 결과를 해당 기관의 장 및 관계 기관의 장에 통보하고 기관평가에 반영할 수 있다.

③ 제2항에 따라 평가 결과를 통보받은 기관의 장은 평가 결과에 따른 미비점을 개선·보완하여 사이버보안 수준을 제고하여야 한다.

④ 성평등가족부장관으로부터 개선대책을 요청받은 기관의 장은 제3항에 따른 문제점 개선·보완 결과를 3개월 이내에 성평등가족부장관에게 통보해야 한다.

제6장 사이버위협 탐지 및 대응

제1절 보안관제

제84조(보안관제센터 설치·운영) ① 성평등가족부장관은 해당 기관의 보안관제를 위해 「사이버안보 업무규정」 제14조제2항에 따라 보안관제센터를 설치·운영하거나 관계기관에 위탁 운영할 수 있다.

[개정 2023. 4. 14.]

② 각 기관의 장은 사이버공격·위협 탐지 및 대응을 위해 다음 각 호

의 사항을 고려하여 보안관제 환경을 구축하여야 한다.

1. 소관 보안관제센터와 침해사고 발생시 대응·기술지원 등을 위한 협력채널 구축
2. 제1호의 보안관제센터로부터 사이버공격·위협을 탐지하기 위한 탐지규칙 수신 및 이를 활용하여 탐지한 결과의 회신
3. 암호화된 사이버공격·위협 패킷을 가시화하는 장비의 구축 또는 장비가 구축된 보안관제센터와의 보안관제 연동
4. 클라우드 도입에 따른 ICT 환경변화에도 제2호의 탐지규칙 수신 및 결과회신이 정상 동작할 수 있도록 「국가 클라우드 컴퓨팅 보안관제 가이드라인」을 준용하여 소관 보안관제센터와 사전 검토·시험 실시
5. 각 기관 도입 EDR(단말 위협탐지 제품)을 보안관제체계와 연동

③ 각 기관의 장은 해당 기관이 이용하는 민간 클라우드컴퓨팅서비스 영역에 대해서도 본 절 및 「국가 클라우드 컴퓨팅 보안관제 가이드라인」에 따른 보안관제가 이루어 질 수 있도록 노력하여야 한다.

제84조의2(탐지규칙정보 개발 및 배포) ① 보안관제센터를 운영하는 기관의 장은 사이버공격·위협을 탐지할 수 있는 기술정보(이하 "탐지규칙정보"라 한다)를 개발하여 보안관제업무에 활용할 수 있다.

② 국가정보원장은 안보위해(危害) 공격에 대한 탐지규칙정보를 개발한 경우 보안관제센터를 운영하는 기관의 장에게 적시에 배포하여야 한다.

③ 제3항에 따라 탐지규칙정보를 배포받은 기관의 장은 이를 필요로

하는 산하기관의 장에게 다시 배포하여야 한다.

④ 보안관제센터를 운영하는 기관의 장은 제1항에 따른 탐지규칙정보를 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보 및 「국가정보자료관리규정」 제2조제1호에 따른 국가정보자료로서 취급·관리하여야 한다.

⑤ 제2항 및 제3항에 따라 탐지규칙정보를 배포받은 기관의 장은 탐지규칙정보를 다음 각 호에 해당하는 방법으로 관리하고 매월 1회 이상 보안관리 실태를 점검하여야 한다.

1. 암호화 저장·전송
2. 인터넷을 통한 평문 송·수신 금지
3. 인터넷 등 외부유출 금지
4. 탐지규칙정보 관리시스템의 원격 접속 금지

⑥ 탐지규칙정보를 배포받은 기관의 장은 탐지규칙정보가 유출된 경우 즉시 그 사실을 성평등가족부장관 및 국가정보원장에게 통보하여야 한다.

제84조의3(공격정보 탐지·처리) ① 보안관제센터를 운영하는 기관의 장과 국가정보원장(「사이버안보 업무규정」 제14조제3항에 따라 합동으로 보안관제를 수행하는 경우를 말한다. 이하 이 절에서 같다)은 보안관제 대상기관에 대한 사이버공격·위협에 관한 정보를 탐지·처리하여야 한다.

② 보안관제센터를 운영하는 기관의 장은 제1항의 업무를 수행하기 위하여 보안관제 대상기관의 장과 협의하여 사이버공격·위협에 관한

정보를 실시간 탐지하는 장비[암호화된 사이버공격 패킷을 가시화(可視化)하는 장비를 포함한다]를 보안관제 대상기관의 정보통신망에 설치·운용하거나 탐지규칙정보를 제공하여 관련 정보를 실시간 탐지·처리할 수 있다.

③ 보안관제센터를 운영하는 기관의 장은 보안관제 과정에서 자동적으로 처리되는 다음 각 호의 정보를 수집·이용할 수 있다.

1. 사이버공격·위협으로 인하여 발생한 패킷
2. 공격 주체 및 피해자를 식별하기 위한 IP주소 및 MAC주소, 전자우편 주소, 정보통신서비스 이용자 계정 정보, 피해자의 성명 및 연락처
3. 그 밖에 사이버공격의 방법 및 피해 확인·식별에 필요한 정보

④ 제2항에 따른 사이버공격에 관한 정보를 실시간 탐지하는 장비 중 암호화 된 사이버 공격 패킷 가시화 장비를 설치하는 경우 보안관제센터, 보안관제 대상기관 등은 가시화 장비가 정상 동작할 수 있도록 다음 각 호에 해당하는 사항을 고려하여야 한다.

1. 암호화 트래픽 이동 경로를 고려하여 가시화 장비 위치 선정
2. 인증서 설치 및 IP 등록
3. 최소 월 1회 점검 절차 마련

제84조의4(초동조치) 각 기관의 장은 사이버공격·위협으로 인한 피해 최소화 및 확산 방지를 위하여 다음 각 호의 사항을 포함한 조치를 취하여야 한다.

1. 사이버공격 경유지(사이버공격에 악용되거나 악용될 우려가 있는 웹사이트 주소, IP주소, 전자우편 주소를 말한다) 및 공격 IP주소 차단

2. 피해 시스템을 정보통신망으로부터 분리하거나 악성프로그램의 동작을 정지시키는 조치

3. 사고 조사를 위한 피해 시스템 및 로그 기록의 보전

제84조의5(조치결과 통보) 사이버공격·위협에 관한 정보를 제공받은 보안관제 대상기관의 장은 제공받은 날로부터 5일 이내에 대응조치 결과를 해당 보안관제센터를 운영하는 기관의 장에게 통보하여야 한다.

제84조의6(인력파견) 성평등가족부 장관은 부처합동 사이버안전센터 운영을 위하여 필요하면 산하기관의 임직원을 파견받아 근무하게 할 수 있다.

제2절 사고 대응

제85조(사이버공격·위협으로 인한 사고) ① 「사이버안보 업무규정」 제16조제1항에 따라 사고조사를 실시할 경우 국가정보원장 및 성평등가족부 장관은 안보위해(危害) 공격으로 인한 사고에 대하여 조사를 실시하며, 해당 기관의 장은 안보위해(危害) 공격을 제외한 사이버공격·위협으로 인한 사고에 대하여 조사를 실시한다.

② 제1항에 따른 조사 기관의 장은 사이버공격·위협으로 인한 사고의 원인 분석 및 재발 방지를 위하여 피해 기관의 장에게 다음 각 호에 해당하는 자료 제출을 요청할 수 있다. 사이버공격·위협으로 인하여 「보안업무규정」 제38조 및 제45조, 「보안업무규정 시행규칙」 제65조의2에 따른 조사를 실시하는 경우에도 같다.

1. 공격 주체 및 피해자를 식별하기 위한 IP주소 및 MAC주소, 전자우편

주소, 정보통신서비스 이용자 계정 정보, 피해자의 성명 및 연락처

2. 사이버공격에 사용된 악성프로그램 및 공격 과정에서 생성·변경 또는 복제된 디지털정보

3. 공격 주체가 절취한 디지털정보

4. 공격 주체의 행위가 기록된 내역 또는 로그기록

③ 제2항에 따른 자료 제출을 요청받은 피해 기관의 장은 관계 법규에 저촉되지 않는 범위 내에서 해당 자료를 제출하여야 하며 조사 기관의 장은 제출받은 자료를 사고원인 분석, 공격자 의도 파악, 피해영향 평가 등 사이버공격·위협에 대한 예방 및 대응과 관련한 목적으로만 사용하여야 한다.

④ 피해 기관의 장은 사고 원인을 규명할 때까지 피해 시스템에 대한 증거를 보전하고 임의로 관련 자료를 삭제하거나 포맷하여서는 아니 된다. 이 경우 증거의 일부 또는 전부를 용역업체가 소지하고 있으면 해당 업체에 자료 삭제·포맷 금지 사항을 즉시 통보하여야 한다.

⑤ 클라우드를 이용하는 기관의 장은 해당 각급기관이 이용하는 클라우드에서 사고가 발생한 경우 조사 기관의 장과 합동으로 조사반을 구성하여 클라우드컴퓨팅서비스제공자에 대하여 계약의 범위 내에서 자료의 보전 및 제출 요구, 현장 조사 등 필요한 조치를 취하여야 한다.

⑥ 산하기관의 장은 제1항에 따라 사고조사를 실시할 경우 사고개요 및 조치내용 등 관련 사항을 성평등가족부장관에게 통보하여야 한다.

⑦ 제5항을 적용함에 있어, 조사기관이 국가정보원인 경우에는 클라우드컴퓨팅서비스제공자에 대하여 「국가정보원법」 제5조제1항에 따

른 사실의 조회・확인, 자료의 제출, 현장 조사 등 필요한 조치를 하여야 한다. 사고조사를 수행하는데 있어 전문 기술이나 인력이 필요한 경우, 국가정보원장에게 지원을 요청할 수 있다.

⑧ 조사 기관의 장은 사고조사를 수행하는데 있어 전문 기술이나 인력이 필요한 경우, 국가정보원장에게 지원을 요청할 수 있다.

제86조(정보통신보안 규정 위반 및 자료유출 사고) ① 각 기관의 장은 국가정보원장으로부터 「보안업무규정 시행규칙」[별표 2]에 따른 정보통신보안 규정 위반사항에 대한 사실을 통보받은 경우 동규정 시행규칙 제66조제3항에 따라 즉시 필요한 조치를 취하고 위규자, 위규 내용 및 조치 결과를 성평등가족부장관을 경유하여 국가정보원장에게 통보하여야 한다.

② 각 기관의 장은 비밀・대외비 등을 포함한 기밀등급 업무자료가 유출되거나 민감등급 업무자료가 유출된 사고 중 「국가정보원법」 제4조제1항제1호 나목부터 마목까지와 관련된 사안일 경우 즉시 국가정보원장에게 통보하여 합동 조사를 실시하여야 한다.

③ 공무원등의 과실로 인하여 개인 소유의 정보통신기기 및 이동통신 단말기, 상용 정보통신서비스에서 제2항에 따른 유출사고가 발생한 경우 조사 기관의 장은 공무원등의 소속된 기관의 장을 통해 해당 공무원등에게 저장자료・이용내역 등의 자료 제출을 요청할 수 있다.

④ 공무원등은 제3항에 따른 요청이 위법하다고 판단하는 경우 그 사유를 소명하고 자료 제출을 거부할 수 있다.

⑤ 조사 기관의 장은 제1항 및 제2항에 따른 조사를 통해 유출이 확인

된 자료에 대하여 관계 기관의 장과 합동으로 국가안보 및 국익, 정부 정책에 미치는 영향을 평가하는 안보영향 평가 등 필요한 조치를 취하여야 한다.

제87조(재발방지 조치) ① 조사 기관의 장은 제85조 및 제86조에 따른 조사 결과 및 재발방지를 위한 보안조치 사항을 해당 기관의 장에게 통보하여야 한다.

② 제1항에 따라 조사 결과를 통보받은 기관의 장은 관계 법규에 따른 관련자 징계, 개선대책 수립·시행 등 필요한 조치를 취하여야 한다.

③ 국가정보원장 및 성평등가족부장관은 해당기관의 장에게 제2항에 따른 재발방지 개선조치에 대한 결과를 회신 요청할 수 있으며, 필요시 추가 개선조치를 요청할 수 있다

제7장 정보 협력

제88조(기관간 정보공유 협력) 각 기관의 장은 사이버공격·위협의 예방 및 신속한 대응을 위하여 다음 각 호에 해당하는 정보(이하 "사이버위협정보"라 한다)를 기관간 상호 공유하도록 노력하여야 한다.

1. 사이버공격·위협의 방법 및 대응조치에 관한 정보
2. 사이버공격·위협에 사용된 악성프로그램 및 이와 관련된 정보
3. 정보통신망, 정보통신기기, 정보보호시스템 및 소프트웨어의 보안 취약점에 관한 정보
4. 그 밖에 사이버공격·위협 예방 및 대응에 필요한 정보

제89조(정보공유시스템 운영) ① 국가정보원장은 사이버안보 정보의

배포와 산하기관·단체간 사이버위협정보의 체계적·효율적 공유를 위하여 국가사이버위협 정보공유시스템(「사이버안보 업무규정」 제6조에 따른 정보공유시스템을 포함한다. 이하 "정보공유시스템"이라 한다)을 구축·운영할 수 있다. 이 경우 「사이버안보 업무규정」 제6조에 따른 정보공유시스템과 그 밖의 정보공유시스템을 별도로 구축·운영할 수 있다.

② 각 기관의 장은 국가정보원장이 정보공유시스템을 통해 배포한 관계 법규 및 이 지침에 따라 작성하는 정보와 각종 매뉴얼·가이드라인 등을 준수하여야 한다.

③ 정보공유시스템을 이용하고자 하는 기관의 장은 국가정보원장에게 이용 신청을 하여야 하며, 국가정보원장에게 접근권한을 부여받아야 한다.

④ 제3항에 따라 접근권한을 부여받은 기관의 장은 정보공유시스템에 사이버위협 관련 정보 등을 등록하거나 등록된 정보를 업무에 활용할 수 있으며 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 정보공유시스템 전용(專用) 단말기 운용
2. 정보공유시스템 접근·활용 및 단말기 운용 등을 위한 관리자 지정·운영
3. 정보시스템 개별 이용자 등록·삭제 등 접근권한 관리
4. 정보공유시스템 전용(專用) 단말기 내 정보공유시스템 이용과 무관한 소프트웨어 설치 및 비인가 휴대용 저장매체 연결 사용 금지
5. 이용기관간 정보공유 활성화를 위하여 월 1회 이상 정보공유시스템

접속・활용

6. 기타 국가정보원장이 제시하는 보안대책

제90조(정보공유시스템의 정보 관리) ① 이용기관의 장은 정보공유시스템에 등록된 정보를「공공기관의 정보공개에 관한 법률」제9조제1항에 따른 비공개 대상 정보 및「국가정보자료관리규정」제2조제1호에 따른 국가정보자료로서 취급・관리함을 원칙으로 한다.

② 이용기관의 장은 정보공유시스템에 사이버위협정보를 등록할 경우 보안성・민감성 등을 고려하여 열람권한 및 보안등급(외부 공개까지를 포함한다)을 부여할 수 있다.

제8장 보 칙

제91조(서약서 징구시 고지 사항) 각 기관의 장은 이 지침에 따라 서약서를 징구・집행하는 대상자에게 다음 각 호의 어느 하나에 해당하는 경우에는 비밀・보안준수의무를 위반하지 아니하는 것으로 본다는 점을 알리기 위하여 노력하여야 한다.

1.「부패방지 및 국민권익위원회의 설치와 운영에 관한 법률」제55조, 제66조제3항 및 제67조에 따른 부패행위 신고 또는 공직자 행동강령 위반행위 신고

2.「공익신고자 보호법」제6조, 제14조제4항에 따른 공익신고

제92조(재검토 기한) 성평등가족부장관은「훈령・예규 등의 발령 및 관리에 관한 규정」에 따라 이 규정에 대하여 2027년 1월 1일 기준으로(매년 3년이 되는 해의 1월 1일전까지를 말한다) 그 타당성을 검토

하여 개선 등 조치를 해야 한다.

제93조(준용) 이 규정(부록을 포함한다)에 명시되지 않은 사항은 「국가 사이버보안 기본지침」을 따른다.

부칙<제1호, 2026.8..>

이 규정은 발령한 날부터 시행한다.

별 표

【 별표 1 】

‘안전성 검증필 제품 목록’ 등재 기본요건

X : 해당사항 없음

<table>
<tr><th rowspan="2">제품 유형</th><th colspan="4">아래 해당되는 항목 중에서 어느 하나 필요</th><th rowspan="2">검증필
암호모듈</th></tr>
<tr><th>CC인증 1)</th><th>성능평가 2)</th><th>보안기능
확인서 3)</th><th>보안적합성
검증 4)</th></tr>
<tr><td>스마트카드</td><td rowspan="23">국가용
보안요구사항

또는

국가용
보호프로파일
(PP)
준수</td><td>X</td><td>X</td><td>○</td><td>X</td></tr>
<tr><td>침입차단시스템</td><td>X</td><td rowspan="24">국가용
보안요구사항
준수</td><td>X</td><td>X</td></tr>
<tr><td>침입방지시스템</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>통합보안관리제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>웹 방화벽</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>운영체제(서버) 접근통제제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>DB접근통제제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>네트워크접근통제제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>인터넷전화 보안제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>무선침입방지시스템</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>무선랜 인증제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>가상화제품(Hypervisor)</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>네트워크 자료유출방지제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>디지털복합기</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>스마트폰 보안관리제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>스팸메일차단시스템</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>패치관리시스템</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>망간자료전송제품</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>DDoS 대응장비</td><td rowspan="3">국가용
보안요구사항
준수</td><td>X</td><td>X</td></tr>
<tr><td>안티바이러스제품</td><td>X</td><td>X</td></tr>
<tr><td>소스코드 보안약점 분석도구</td><td>X</td><td>X</td></tr>
<tr><td>가상사설망제품</td><td>X</td><td>X</td><td>탑재 필요</td></tr>
<tr><td>호스트 자료유출방지제품</td><td>X</td><td>X</td><td>탑재 필요</td></tr>
<tr><td>S/W기반 보안USB제품</td><td>X</td><td>X</td><td>X</td><td>탑재 필요</td></tr>
<tr><td>가상화관리제품</td><td>X</td><td>X</td><td>X</td><td>X</td></tr>
<tr><td>네트워크 장비 5)</td><td>X</td><td>X</td><td>X</td><td>X</td></tr>
</table>

1) 「지능정보화 기본법」 제58조제1항 및 같은 법 시행령 제51조에 따라 과학기술정보통신부장관이 고시한 「정보보호시스템 평가·인증 지침」에 따른 인증(국내용 CC 또는 국제용 CC). 다만, 인증범위(TOE)에 각급기관이 사용할 보안기능이 포함되어 있어야 함

2) 「정보보호산업의 진흥에 관한 법률」 제17조에 따른 성능평가

3) 본 지침 제19조의2에 따라 보안기능 시험기관이 발급하는 확인 증서

4) 본 지침 제2장제5절에 따른 보안적합성 검증

5) 망간자료전송제품은 2022.1월부터 'CC인증'에서 '보안기능 확인서'로 도입요건이 변경됨

6) 네트워크 장비는 L3 이상 스위치 및 라우터 등을 의미

※ 다수 H/W에 탑재, 배포되는 제품이 "CC인증" 또는 "보안기능 확인서"를 발급받은 경우, 해당 인증서 또는 보안기능 확인서에 H/W 모델명 기재 필요

※「소프트웨어 진흥법」 제20조에 따른 품질인증(GS인증)을 받은 제품 중에서 국가용 보안요구사항을 준수하는 제품의 목록 등재에 관하여는 국가정보원 홈페이지 참고

※ 同 지침 시행일로부터 차후에 지침이 개정되는 날까지의 기간 중에, 국가정보원 홈페이지에 同 별표의 변경이 공지될 수 있으며, 이 경우 홈페이지에 공지된 별표 내용을 同 지침상의 별표로 봄

【 별표 2 】

‘암호가 주기능인 제품’ 도입요건

제품 유형	도입 요건	비 고
메일 암호화제품	검증필 암호모듈 탑재	
구간 암호화제품		
하드웨어 보안토큰		
디스크・파일 암호화제품		
기타 암호화제품		
SSO제품	검증필 암호모듈 탑재 및 CC인증(국가용 보호프로파일 준수)	
DB 암호화제품		
문서 암호화제품(DRM 등)		

※ 최신 도입요건은 국가정보원 홈페이지(암호모듈 검증) 참조

【 별표 3 】

보안적합성 검증 신청시 제출물

1. 최초검증 신청시 제출물

제출물	정보보호시스템		작성 주체
	상용 제품	자체(용역) 개발	
[서식 제1호]에 따른 보안적합성 검증 신청서	○	○	신청기관
[서식 제3호]에 따른 정보통신제품 도입확인서(현황)	○	○	
기술제안요청서 사본	○	○	
보안기능 점검표	○	○	
운용점검사항	○	○	
CC인증서 사본	○ (인증서 보유시)		업체
보안기능 운용 설명서	○	○	
기본 및 상세 설계서		○	
개발완료 보고서		○	

2. 재검증 신청시 제출물

제출물	정보보호시스템		작성 주체
	상용 제품	자체(용역) 개발	
[서식 제1호]에 따른 보안적합성 검증 신청서	○	○	신청기관
[서식 제3호]에 따른 정보통신제품 도입확인서(현황)	○	○	
보안기능 점검표	○	○	
운용점검사항	○	○	
변경내용 분석서	○	○	업체

【 별표 4 】

클라우드 서비스 이용 '시스템 중요도' 등급 분류기준

등급	분류기준		영역분리
상	파급영향	- 해당 정보시스템에 대한 침해는 운영기관, 자산 및 개인에게 치명적 악영향을 미칠 수 있음	물리적
	분류기준	- 국가 중대 이익(안보, 국가안전, 국방, 통일, 외교 등), 수사·재판 등 민감정보를 포함하거나 행정 내부업무 등을 운영하는 시스템	
중	파급영향	- 해당 정보시스템에 대한 침해는 운영기관, 자산 및 개인에게 심각한 영향을 미칠 수 있음	물리적
	분류기준	- 비공개 업무자료를 포함 또는 운영하는 시스템	
하	파급영향	- 해당 정보시스템에 대한 침해는 운영기관, 자산 및 개인에게 제한적인 영향을 미칠 수 있음	물리적 또는 논리적
	분류기준	- 개인정보를 포함하지 않고 공개된 공공데이터를 포함 또는 운영하는 시스템	

[표] 시스템 중요도 등급 분류기준 및 영역분리

※ 행정 내부업무의 경우 '시스템 중요도'를 고려하여 등급 조정 가능

※ 위 분류기준에 따른 분류 절차 및 체크리스트 등 세부사항은 '국가 클라우드서비스 보안가이드라인'을 참고한다.

※ 이용기관은 민간 클라우드서비스 도입시 시스템 등급을 자체 분류하고, 국정원은 '보안성 검토' 시 분류의 적정성을 재검토한다.

서 식

【 서식 제1호 】

보안적합성 검증 신청서

<table>
<tr><td rowspan="6">신청
기관</td><td>기관명</td><td></td><td>담당자</td><td></td></tr>
<tr><td>부서명</td><td></td><td>전화번호</td><td></td></tr>
<tr><td>사업명</td><td></td><td>이메일
※ 상용메일 불가</td><td></td></tr>
<tr><td>도입 목적</td><td colspan="3"></td></tr>
<tr><td rowspan="2">보안성
검토명</td><td rowspan="2"></td><td>계약 날짜</td><td></td></tr>
<tr><td>도입 날짜</td><td></td></tr>
<tr><td>검증결과 반영</td><td colspan="3">취약점 등의 개선요청 이행 (□ 반영・개선 □ 반영불가)</td></tr>
<tr><td rowspan="8">신청
제품</td><td>제품명</td><td>※ 신청 제품이 2種 이상인 경우, 별도 신청</td><td>S/W(펌웨어)
버전</td><td></td></tr>
<tr><td>제품 유형</td><td></td><td>도입 수량</td><td>대</td></tr>
<tr><td>사전 인증
대상 여부</td><td colspan="3">□ CC인증 대상 □ 검증필 암호모듈 탑재
□ 해당 없음

※ CC인증・검증필 암호모듈 탑재 필수 제품은 국정원 홈페이지 참조</td></tr>
<tr><td>해시값
(SHA-512)</td><td colspan="3">※ 해시값은 국정원 홈페이지에 게시된 S/W 사용</td></tr>
<tr><td>CC 인증기관</td><td></td><td>CC 인증등급</td><td></td></tr>
<tr><td>CC 인증번호</td><td></td><td>CC 만료일</td><td></td></tr>
<tr><td>암호모듈명</td><td></td><td>암호검증
번호</td><td>CM-</td></tr>
<tr><td rowspan="4">업체</td><td>업체명</td><td></td><td>대표자</td><td></td></tr>
<tr><td>주소</td><td colspan="3"></td></tr>
<tr><td>담당자명</td><td></td><td>전화번호</td><td></td></tr>
<tr><td>휴대폰번호</td><td></td><td>이메일</td><td></td></tr>
</table>

※ △서식이 변경될 수 있으므로 국가정보원 홈페이지(든든한 안보→사이버안보→보안적합성 검증 →검증 공지사항)에 게시된 양식을 참고 △'검증결과 반영'을 포함하여 기재 양식中 해당사항은 빠짐없이 기재

【 서식 제2호 】삭제

【 서식 제3호 】

정보통신제품 도입 확인서(현황)

기관명		관계 중앙행정기관	
담당자		담당자 전화번호	
사업명			
보안성	보안성 검토받은 문서 제목 및 번호 표시 예) 000 보안성 검토결과(000-000, 2019.1.1)		

기관명	관계 중앙행정 기관	제품명	제조사	제품 유형	보안기능 확인서			CC인증, GS인증, 성능평가			암호모듈검증 (KCMVP)		펌웨어 또는 OS버전	해시값 (SHA-512)	비고
					발급 번호	시험 기관	발급일	인증 번호	등급 또는 준수PP	인증 기관	암호 모듈명	암호 검증 번호			
				L3 스위치	ND-0001-0001-2019		2019-01-01		NDcPP			CM-00-000.0	이름 또는 버전		수량 등

※ △서식이 변경될 수 있으므로 국가정보원 홈페이지(든든한 안보→사이버안보→보안적합성 검증→검증 공지사항)에 게시된 양식을 참고하되, 반드시 엑셀(xlsx)양식을 준수 △해시값은 국가정보원 홈페이지에 등재된 S/W 활용

【 서식 제4호 】

정보시스템 관리대장

연번	소속	취급자 성명	종류 (서버·PC 등)	제조사	모델명	관리번호	도입일자	비고

【 서식 제5호 】

전파측정 결과보고서

1. 일반 사항

가. 측정 기간 및 지역

나. 측정 장비

다. 참여기관 및 인원

2. 측정 결과

기간	측정지점	통신구간	주파수 (MHz)	신호세기 (dBM)	취약여부	비고
						디지털/ 아날로그 구분

3. 분석 및 평가

4. 조치 및 대책

【 서식 제6호 】

보안관제센터 운영현황

<table>
<tr><th colspan="5">보안관제센터 개요</th></tr>
<tr><td colspan="2">개소</td><td>* 개소일자</td><td>위치</td><td></td></tr>
<tr><td colspan="2">규모</td><td>* 상황실 면적 등</td><td>예산</td><td>* 구축예산 및 운영예산</td></tr>
<tr><th colspan="5">조직 현황</th></tr>
<tr><td colspan="2">개요</td><td colspan="3">* 조직구성, 인원 및 임무, 근무형태 등</td></tr>
<tr><td rowspan="3">1</td><td>부서</td><td></td><td>센터장</td><td></td></tr>
<tr><td>직급</td><td></td><td>성명</td><td></td></tr>
<tr><td>이메일</td><td></td><td>연락처</td><td>전화: HP:</td></tr>
<tr><td rowspan="3">2</td><td>부서</td><td></td><td>직급/직책</td><td></td></tr>
<tr><td>담당분야</td><td></td><td>성명</td><td></td></tr>
<tr><td>이메일</td><td></td><td>연락처</td><td>전화: HP:</td></tr>
<tr><td>3</td><td>:</td><td colspan="3">* 센터장과 탐지・분석・대응 등 분야별 대표자만 기입</td></tr>
<tr><th colspan="5">외부인력 현황</th></tr>
<tr><td colspan="2">업체명</td><td></td><td>대표이사</td><td></td></tr>
<tr><td colspan="2">인원수</td><td></td><td>근무형태</td><td></td></tr>
<tr><td colspan="2">계약기간</td><td></td><td>수행업무</td><td></td></tr>
<tr><th colspan="5">지침・매뉴얼 현황</th></tr>
<tr><td colspan="2">지침</td><td></td><td>기준</td><td></td></tr>
<tr><td colspan="2">매뉴얼</td><td></td><td>기타</td><td></td></tr>
<tr><th colspan="5">보안관제시스템 현황</th></tr>
<tr><td colspan="2">시스템명</td><td>* 주요 기능</td><td>시스템명</td><td></td></tr>
<tr><td colspan="2">시스템명</td><td></td><td>시스템명</td><td></td></tr>
<tr><td colspan="2">시스템명</td><td></td><td>시스템명</td><td></td></tr>
<tr><th colspan="5">보안장비 현황</th></tr>
</table>

F/W	* 제품명 및 사용대수	IDS/IPS	
ESM		WEB F/W	
라우터		그 밖의 장비	예) NMS 1대 * 네트워크 구성도 사본 제출

보안관제 연동기관 현황

* 대상기관 수, 기관명, 대상목표(인터넷 또는 내부망, 홈페이지 등)

연동기관 IP할당 현황

1	연동기관		IP 관리자	성 명	
	공인IP			연락처	전화: HP:
	사설IP			이메일	
2					
3					
4					
5					
6					

국가사이버안보센터 탐지규칙 재배포 현황

기관명	배포방법	기관명	배포방법

부 록

【 부록 1 】

정보보안점검 체크리스트

1. 정보보안 기본활동

연번	세부 점검사항	비고
1	기관 자체 실정에 맞는 정보보안업무 내규를 수립하고 있는가?	
2	매년 정보보안업무 활동계획을 수립・시행하는가?	
3	정보보안업무 전담 조직 및 직원(정보보안담당관)이 지정되어 있는가?	
4	소속 직원 근무성적 평가시 정보보안업무규정 준수여부를 반영하고 있는가?	
5	소속・산하기관 대상 정보보안 감사 또는 점검을 실시하는가?	
6	소속・산하기관 대상 정보보안 교육을 실시하고 있는가?	
7	사이버보안진단의 날을 내실 있게 수행하는가?	
8	정보보안 침해사고・규정위반 및 정보통신망 장애발생을 대비한 보고체계・조치절차가 마련되어 있는가?	
9	보직변경 등 인사이동시 정보시스템 접근권한을 신속하게 조정하는가?	
10	서버・PC 등 정보시스템 현황을 제대로 파악하는가?	
11	정보통신장비(노트북 등) 반출입 통제 및 현황 관리를 철저히 하는가?	
12	업무자료를 상용 정보통신서비스로 전송하고 있지 않는가?	
13	정보통신망 구축 및 유지보수를 수행하는 외부인력(보안관제인력 포함)에 대해 보안서약서 징구, 보안교육 등 충분한 보안조치를 하고 있는가?	
14	용역업체 직원의 내부 정보시스템 접근을 통제하고 있는가?	
15	홈페이지 등 외부 게시자료에 대한 정보공개 지침을 수립・반영하는가?	
16	중요 정보화사업에 대하여 보안성 검토절차를 이행하는가?	
17	정보보호시스템(상용 암호모듈 포함) 도입시 보안적합성 검증절차를 준수하는가?	
18	비밀을 전자적으로 처리할 경우 암호자재로 암호화하는 등 규정을 준수하는가?	

2. PC 및 서버 보안관리

연번	세부 점검사항	비고
1	PC・서버에 설치된 운영체제 및 응용프로그램을 최신 보안업데이트 하였는가?	
2	PC・서버의 불필요한 서비스를 검토하여 중단하고 정기적으로 인터넷에서 접속 가능여부를 확인하는가?	
3	백신이 자동 업데이트되고 실시간 감시기능이 설정되어 있는가?	
4	인터넷 PC에 업무관련 자료(비밀 포함)가 방치되어 있는가?	
5	P2P, 웹하드, 상용메신저 등 업무와 무관한 비인가 프로그램이 설치되어 있는가?	
6	비인가자 접근방지를 위해 CMOS・로그인 등 PC 비밀번호를 설정하였는가?	
7	서버내 저장자료는 중요도에 따라 접근권한이 설정되어 있는가?	
8	정보통신망 구성측면에서 PC 및 서버 등의 위치가 적정한가?	
9	비인가 휴대용 저장매체(USB, 외장형 하드디스크, 메모리카드 등) 사용기록이 존재하는가?	
10	전자우편은 발신지 IP의 국가명이 표시되고 해킹메일은 신고가 용이한가?	
11	비밀은 비밀용 USB를 별도 지정하여 사용하고 일반자료와 혼합 저장하지 않는가?	
12	정보보호시스템・서버・네트워크장비 등 로그기록을 1년 이상 유지・관리하는가?	
13	비인가 USB・정보통신기기 연결시 차단토록 보안 설정되어 있는가?	
14	PC・노트북 등 저장매체가 있는 기기 고장시 저장된 자료의 완전 삭제를 확인하고 외부에 수리를 의뢰하는가?	
15	「정보시스템 저장매체 불용처리지침」에 의거, 저장매체를 불용하였는가?	
16	모바일 업무는 행정업무와 현장업무를 구분하고 별도의 단말기를 운영하는가?	
17	불필요한 원격접속 S/W는 비활성화 또는 제거하였는가?	
18	상주 용역업체 네트워크와 직원용 네트워크를 분리하였는가?	
19	네트워크 접근제어를 위한 보안정책을 적절하게 설정하였는가?	
20	네트워크 접근제어 정책에 대한 생성일・목적・요청자 등 이력을 관리하는가?	
21	주요 정보보호시스템의 보안정책 설정파일을 주기적으로 백업하고 있는가?	

3. 네트워크 보안관리

연번	세부 점검사항	비고
1	정보시스템 세부 구성도(IP 포함)를 최신으로 유지하는가?	
2	업무자료를 소통하기 위한 내부망은 인터넷과 분리 운영하는가?	
3	인터넷·업무망간 자료공유 방안이 적절한가?	
4	업무자료를 소통하기 위한 내부망 구축시 사설주소체계(NAT)를 적용하는가?	
5	국가정보원장이 안정성을 검증한 정보보호시스템을 운용하고 있는가?	
6	인가받지 않은 단말기가 네트워크에 연결하지 못하도록 조치하고 있는가?	
7	네트워크를 통한 파일공유를 제한하고 필요시 보안대책을 세우고 있는가?	
8	장비 신규도입 등 전산망 구성 변동시 관련사항을 기록하는가?	
9	비인가 무선인터넷·무선랜 등 허가받지 않은 인터넷 접속경로가 존재하는가?	
10	첨단 정보통신기기(IoT 등)에 의한 내부 업무자료 유출 가능성이 존재하는가?	
11	시스템 최초 설치시 등록된 초기 계정·패스워드를 변경하였는가?	
12	네트워크 장비·정보보호시스템·서버는 비인가자가 접속하지 못하도록 IP 통제 등 보안설정하고 불필요한 서비스포트를 제거하는가?	
13	네트워크 장비·정보보호시스템·서버 등의 관리자 네트워크를 인터넷·업무망과 별도로 분리하여 운용하고 있는가?	
14	무선네트워크 구축시 사전에 보안성 검토를 수행하고 보안대책을 준수하는가?	
15	정보시스템에 대한 보안취약점을 주기적으로 점검하는가?	
16	소프트웨어개발보안(시큐어코딩)을 적용하여 개발하였는가?	
17	원격지 개발시 개발장소를 점검하고 있는가?	
18	원격 유지보수를 금지하고 비인가 원격접속을 차단하는가?	
19	직원의 재택·파견·이동근무 등 원격근무시 보안관리 대책이 적절한가?	
20	음란·도박 등 유해사이트를 차단하고 사이트목록을 주기적으로 갱신하는가?	
21	해외에 위치한 사무소와 인원에 대해 보안대책을 지원하고 주기적으로 점검하는가?	
22	인터넷전화 제품은 TTA Verified Ver 4. 이상을 사용하는가?	
23	인터넷전화는 인터넷망에 설치된 경우 물리적으로 분리하고, 업무망에 설치된 경우 물리적 또는 논리적(VLAN)으로 분리하였는가?	
24	서버가 위치한 네트워크는 방화벽 등으로 사용자 네트워크와 분리하고 있는가?	

4. 정보통신시설 보안관리

연번	세부 점검사항	비고
1	인위적・자연적 원인에 의한 정보통신망 장애 대비 백업 등 재난방지 대책을 강구하였는가?	
2	통합전산센터, 정보통신실 등 중요 정보통신시설을 보호구역으로 관리하는가?	
3	사무실 책상서랍 등에 비밀문건이나 비인가 정보통신기기가 방치 여부를 주기적으로 확인하는가?	
4	외부인의 정보통신실 출입을 통제하고 기록을 유지하는가?	
5	무정전 전원공급장치 등 비상시 전력장애 대책을 강구하였는가?	
6	침입경보장치, CCTV 등 보안장비와 방화장비(하론소화기 등) 정상동작 여부를 정기적으로 점검하고 있는가?	
7	정보통신시설에 비상시 긴급 파기를 위한 장비(해머 등)를 비치하고 있는가?	
8	정보통신시설에 대한 접근권한을 업무목적에 따라 차등 적용하고 있는가?	
9	정보통신장비 수리・점검시 정보보안담당관 또는 분임정보보안담당관 입회하에 진행하는가?	
10	민간 클라우드 컴퓨팅서비스 사용시 보안인증을 받은 서비스를 이용하는가?	
11	계약서에 정보통신망 구성도, IP주소현황 등 누출금지정보를 명시하고 있는가?	
12	시각동기화를 통하여 정보시스템 시각을 정확히 유지하고 있는가?	
13	CCTV 등 단독망 형태의 시스템을 인터넷망과 혼용하지 않고 분리・운영하는가?	

5. 암호자재 및 암호알고리즘 관리

연번	세부 점검사항	비고
1	비밀을 소통·보호하기 위하여 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 사용하는가?	
2	국가정보원장이 승인하지 아니한 암호자재 또는 외국에서 생산된 암호기능 탑재 시스템을 무단으로 사용하는가?	
3	암호자재를 취급하는 인원을 암호자재 취급자로 지정·관리하는가?	
4	암호자재 취급인가자 중 암호자재 배부 또는 반납하는 직원에 대해 인감등록을 실시하는가?	
5	각 암호자재에 대한 운용관리 정·부책임자 및 실무 담당자를 지정하였는가?	
6	암호자재 설치, 운영, 보관에 대한 보안대책이 수립되었으며 이행되고 있는가?	
7	암호자재를 복제·복사하거나 또는 국가정보원장이 승인 없이 암호자재를 해외 제공·반출한 사례는 없는가?	
8	암호자재 관련 문서를 비밀로 생산하여 관리하고 있는가?	
9	사용중인 암호자재의 사용목적 및 보호대상 변경 시, 국가정보원장에게 승인을 받았는가?	
10	노후 등으로 사용하지 않거나 또는 도입 후 6개월 이내에 설치하지 않는(미래용·예비용 암호자재 제외) 등 보관만 하고 있는 암호자재가 있는가?	
11	'암호자재 관리기록부', '암호자재 점검기록부', '지편자재 사용기록부' 등을 누락하지 않고 작성·유지하고 있는가?	
12	암호자재 책임자는 주1회 이상 암호자재를 점검하여 그 결과를 '암호자재 점검기록부'에 기록·유지하고, 보안담당관은 점검사항을 월 1회 확인하고 있는가?	
13	암호자재 배부·반납 등의 업무는 암호자재 취급자가 직접 수행하고, '암호자재 증명서'를 작성·보관하고 있는가?	
14	암호자재의 정·부 책임자 및 실무 담당자 교체시 인계인수를 실시하고 '암호자재 관리기록부'에 인계인수 사항을 기록하는가?	

6. 보안관제 등 해킹 대응활동

연번	세부 점검사항	비고
1	사이버공격에 대응하기 위해 자체 관제센터를 운영(직접 혹은 보안관제 전문업체 용역)하거나 다른 국가・공공기관에 위탁 하였는가?	
2	보안관제센터 운영을 총괄 관리하는 전담 공무원이 있는가?	
3	사이버공격 탐지・대응 및 자체 DDoS공격 대응매뉴얼 등이 구비되어 있는가?	
4	해킹사고 조사결과, 보안 위규자에 대한 처벌이 자체 규정・지침 등에 명시되어 있고 실제로 이루어지고 있는가?	
5	국가사이버안전센터・부문보안관제센터 등 유관기관과 보안관제시스템을 연계 운영하는가?	
6	자체 사이버위기 대응 모의훈련을 주기적으로 실시하는가?	
7	홈페이지 해킹, DDoS공격, 해킹메일 수신 등 침해사고 발생시 국가정보원・여성가족부 등 유관기관에 즉시 신고하는가?	
8	시스템 장애시 유지보수 업체 및 긴급연락체계가 최신화 되어 있는가?	
9	보안관제시스템에 대한 물리적・관리적・기술적인 보안대책을 준수하고 있는가?	
10	침해사고 발생시 사고조사내역을 작성하고 해당내용을 기관장에 보고하는가?	
11	전직원을 대상으로 해킹메일 대응방안 및 침해사고 대응절차 등 관련 교육을 수행하는가?	
12	보안취약점 발표시 산하기관 또는 담당직원과 즉시 공유하는가?	
13	국가사이버안전센터 등과 사이버위협정보, 탐지기술 등 정보를 공유하고 있는가?	
14	사이버공격 발생시 소속・산하기관에 전파할 수 있는 체계가 구비되었는가?	
15	국가사이버안전센터에서 제공한 탐지규칙정보에 대한 보안관리 및 전담관리자를 지정・운영하고 있는가?	
16	침해사고 발생시 해당 시스템을 무단 포맷할 경우 보안위규(사고조사 방해) 행위임을 시스템 관리자・사용자가 인지하고 있는가?	

【 부록 2 】

USB메모리 등 휴대용 저장매체 보안관리지침

제1조(목적) 이 지침은「성평등가족부 사이버보안 업무규정」제68조제9항에 따라 USB(Universal Serial Bus)메모리 등 휴대용 저장매체 보안관리에 필요한 세부사항을 규정함을 목적으로 한다.

제2조(적용범위) 이 지침은「성평등가족부 사이버보안 업무규정」제3조의 적용범위를 따른다.

제3조(정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. "휴대용 저장매체"라 함은 디스켓·CD·외장형 하드디스크·USB메모리 등 정보를 저장할 수 있는 것으로 PC·서버 등의 정보시스템과 분리할 수 있는 기억장치를 말한다.

2. "휴대용 저장매체 관리자"(이하 "관리자"라 한다)라 함은 각 팀 또는 과별 휴대용 저장매체 관리상의 책임을 맡은 부서의 장을 말한다.

3. "휴대용 저장매체 취급자"(이하 "취급자"라 한다)라 함은 해당 휴대용 저장매체를 사용하는 자를 말한다.

4. "휴대용 저장매체 관리시스템"(이하 "관리시스템"이라 한다)이라 함은 휴대용 저장매체의 등록, 파기, 재사용, 반출·입 및 불용처리 현황 등에 관하여 전자적으로 처리하는 시스템을 말한다.

5. "휴대용 저장매체 관리번호"(이하 "관리번호"라 한다)라 함은 사용 중인 휴대용 저장매체의 식별 및 관리를 용이하게 하기 위하여 부여한 번호를 말한다.

제4조(USB메모리 및 관리시스템 도입절차) ① 각 기관의 장은 상용 암호모듈이 탑재된 휴대용 저장매체 및 휴대용 저장매체 관리시스템을 도입할 경우 그 제품의 안전성을 검증하기 위하여「성평등가족부 사이버보안 업무규정」제2장 제2

절에 따라 보안적합성 검증 절차를 이행하여야 한다.

② 보안적합성 검증기관의 장은 다음 각 호에 해당하는 필수 보안기능의 유무를 검토한 후 그 결과를 적합성 검증결과에 반영한다.

1. 사용자 식별·인증기능

2. 저장데이터 암・복호화 기능

3. 저장된 자료의 임의 복제 방지기능

4. 분실시 저장데이터의 보호를 위한 삭제 기능

③ 제2항제2호의 저장데이터 암・복호화 기능은 자료를 휴대용 저장매체에 보관하는 경우로 한한다.

④ 각 기관의 장은 운용중인 휴대용 저장매체를 별지 제1호부터 별지 제6호까지의 서식으로 관리하여야 하며 전자적 관리시스템으로 갈음할 수 있다.

제5조(휴대용 저장매체 사용) ① 각 기관은 휴대용 저장매체를 등록한 후 사용하여야 한다.

② 휴대용 저장매체의 등록방법은 제4조제4항에 따른 서식 또는 전자적 관리시스템으로 등재하는 것을 말한다.

제6조(휴대용 저장매체 사용제한) ① 각 기관은 등록된 휴대용 저장매체만 사용할 수 있다.

② 각 기관의 장은 그 소속직원이 국제회의에 참가시 출장 전 회의 대상국에서 제공한 USB메모리 등 휴대용 저장매체를 사용하지 않도록 보안교육을 실시한다.

③ 각 기관의 장은 그 소속직원에게 공지・교육을 통하여 미등록 휴대용 저장매체 사용을 제한하여야 하고 이에 대해 주기적인 점검을 실시하여야 한다.

제7조(관리자) ① 관리자는 소관 부서에서 휴대용 저장매체를 사용할 경우, 제4조제4항에 따른 서식 또는 전자적 관리시스템에 등재하여야 하며, 서식일 경우 사본 1부를 부서 분임사이버보안담당관에게 제출하여야 한다.

② 관리자는 정기적으로 휴대용 저장매체의 수량 및 보관상태를 점검하고 별지 제3호 서식 또는 전자적 관리시스템으로 관리하여야 한다.

③ 관리자는 휴대용 저장매체의 반・출입을 통제하여야 하며 별지 제4호 서식 또는 전자적 관리시스템에 따라 기록하여야 한다. 다만, 각 기관의 장이 보안강화를 위하여 중앙에서 휴대용 저장매체의 반·출입 통제가 필요하다고 판단하는 경우에는 사이버보안담당관 또는 분임사이버보안담당관에게 그 역할을 부여할 수 있다.

④ 관리자는 소속직원이 휴대용 저장매체를 무단 반출하거나 미등록 휴대용 저장매체를 사용하지 않도록 감독하여야 하며 이를 위반한 사실을 발견 또는 확인하는 즉시 사이버보안담당관에게 통지하여야 한다.

제8조(휴대용 저장매체의 구분 및 관리요령) ① 휴대용 저장매체는 일반용, 비밀용으로 구분한다.

② 일반용 휴대용 저장매체(이하 "일반용" 이라 한다)의 관리요령은 다음과 같다.

1. 일반자료는 일반용에 보관할 수 있다. 다만, 대외비 자료는 국가정보원장이 안전성을 확인한 상용 암호모듈을 사용한 일반용에 보관하여야 한다.

2. 일반용에는 업무관련 일반자료(공개 또는 비공개 자료)만 보관하여야 하며 별지 제1호 서식의 관리대장에 기록하여야 한다.

3. 일반용은 개인서랍, 캐비닛 등에 안전하게 보관하여야 한다.

4. 일반용에는 별지 제5호 서식과 같이 기입·표시하여야 한다.

5. 관리번호는 팀·과명, 일반, 연번으로 한다. 이 경우 팀·과명은 약칭을 사용할

수 있다.(예 : 총무과-일반-01, 총무과-일반-02, 총무-일반-03 등)

③ 비밀용 휴대용 저장매체(이하 "비밀용"이라 한다) 관리요령은 다음과 같다.

1. 비밀용을 사용할 경우에는 별지 제2호 서식의 관리대장에 기록하여야 하며 비밀관리기록부에도 등재·관리하여야 한다.

2. 비밀용은 비밀자료와 동일하게 이중 캐비닛 또는 금고에 보관하여야 한다.

3. 비밀용에는 별지 제5호 서식과 같이 기입·표시하여야 한다.

4. 비밀용을 사용하여 비밀작업을 하는 경우 그 작업을 완료하거나 일시 중단할 때에는 PC에서 즉시 분리하여야 한다.

5. 비밀용은 해당 비밀을 생산하거나 보관할 필요가 있는 경우 비밀등급별로 각각 휴대용 저장매체를 마련해야 하며, 하나의 휴대용 저장매체에 등급이 다른 비밀 또는 일반자료를 혼합 보관해서는 아니 된다.

6. 관리번호는 팀·과명, 비밀등급, 연번으로 한다. 이 경우 팀·과명은 약칭을 사용할 수 있다.(예 : 총무과-Ⅱ급-01, 총무과-Ⅲ급-01 등)

④ 제3항과 관련된 비밀의 전자적 처리와 관련한 그 밖의 사항에 대해서는「국가 사이버보안 기본지침」을 준용한다.

제9조(휴대용 저장매체 불용처리 및 재사용) ① 휴대용 저장매체를 불용처리시 그 사실을 관리대장에 기록하여야 한다.

② 휴대용 저장매체를 불용처리하거나 재사용하는 경우에는 별지 제6호 서식에 따라 분임사이버보안담당관의 확인을 받아야 한다.

제10조(휴대용 저장매체의 분실, 소각시 대처방안) ① 취급자는 휴대용 저장매체의 분실 또는 소각 등의 사유가 발생한 즉시 관리자에게 그 사실을 보고하여야 한다.

② 관리자는 휴대용 저장매체의 분실 또는 소각사실을 보고받은 즉시 분임사이버보안담당관을 경유하여 사이버보안담당관에게 통지하여야 한다.

③ 사이버보안담당관은 일반용의 분실 또는 소각 사실을 통지받거나 인지한 경우에는 자체 조사를 실시하고 재발방지 대책을 강구하여야 한다. 다만「성평등가족부 사이버보안 업무규정」제81조제2항에 따른 사안일 경우에는 지체 없이 국가정보원장 및 성평등가족부의 장에게 그 사실을 통보하여야 한다.

제11조(휴대용 저장매체 외부수리 방안) ① 휴대용 저장매체의 고장, 자료의 훼손 또는 자료의 오인삭제, 포맷으로 자료의 복구가 필요한 경우 상용 소프트웨어 활용 및 민간업체에 의뢰할 수 있다.

② 제1항에 따라 민간업체에 의뢰하는 경우에는 분임사이버보안담당관 입회, 보안서약서 징구 등 적절한 보안대책을 강구하여야 한다. 다만, 비밀자료가 포함된 경우에는 우선 성평등가족부의 장을 경유하여 국가정보원장에게 통보하여야 한다.

< 별지 제1호 서식 >

휴대용 저장매체 관리대장(일반용)

< 관리자 : 4급 이순○ >

연번	관리번호 (S/N)	매체형태	등록일자	취급자	불용처리일자	불용처리방법 (재사용 용도)	비고
1	총무과-일반-01 (E-D900-04-3705B)	USB	10.10.20	5급 홍길○	11.10.20	물리적 파기	고장
2	총무과-일반-02 (NP00T512787J)	외장형 HDD	10.10.25	6급 김정○	11.10.27	포맷후 재사용 (시설과-일반-01)	
3	총무과-일반-03 (E-D900-04-3705B)	USB	10.11.1	5급 이수○	11.10.7	물리적 파기	고장
4							
5							
6							
7							
8							
9							
10							
11							
12							
13							
14							
15							
16							
17							
18							
19							
20							

< 별지 제2호 서식 >

휴대용 저장매체 관리대장(비밀용)

< 관리자 : 4급 김유○ >

연번	관리번호 (S/N)	등급	매체형태	등록일자	취급자	불용처리일자	불용처리방법 (재사용 용도)	비고 (사유)
1	총무과-Ⅱ급-01 (610-RURQ-61750)	Ⅱ급	USB	10.10.20	5급 홍길○	11.10.20	자성소거 후 재사용 (총무과-일반-09)	
2	총무과-Ⅲ급-01 (5101-53RB-12589)	Ⅲ급	CD	10.10.25	7급 정약○	11.10.21	물리적 파기	고장
3								
4								
5								
6								
7								
8								
9								
10								
11								
12								
13								
14								
15								
16								
17								
18								
19								
20								

< 별지 제3호 서식 >

휴대용 저장매체 점검대장

< 관리자 : 4급 김유○ >

점검일시	현 보유수량				이상 유무	점검관		비고 (서명)
	Ⅱ급	Ⅲ급	대외비	일반		성명	서명	
2022.9.8	1	1	3	15	이상무	5급 홍길○	*홍길○*	*김유○*
2022.9.8	1	1	2	16	이상무	5급 홍길○	*홍길○*	*김유○*
2022.9.8	1	1	2	16	이상무	5급 홍길○	*홍길○*	*김유○*
2022.9.8	1	1	2	17	이상무	5급 홍길○	*홍길○*	*김유○*

< 별지 제4호 서식 >

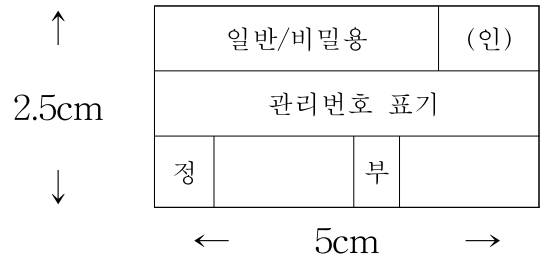
휴대용 저장매체(전산장비 포함) 반출·입 대장

< 관리자 : 4급 김유○ >

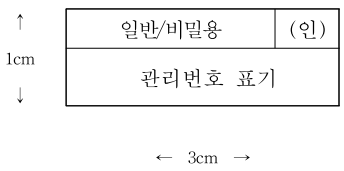
장비명	관리번호 (시리얼번호)	사용자	용도	출입 일시 (입·출 구분)	확인
USB	총무-일반-01 (610-RUCW-61659)	5급 홍길○	국회 제출	2011.10.1 11:00(출)	*김유○*
CD	총무-일반-03 (4589-KK-4585)	5급 유관○	법무부 회의참석	2011.10.7 09:40 (출)	*김유○*
CD	총무-일반-03 (1258-JK-8935)	5급 유관○	법무부 회의참석 회수	2011.10.7 17:50(입)	*김유○*
USB	총무-일반-01 (610-RUCW-61659)	5급 홍길○	국회제출 회수	2011.10.8 18:10 (입)	*김유○*
노트북PC	s111-001-113 (5004829800055)	5급 홍길○	세미나 발표	2011.12.3 13:00 (출)	*김유○*
USB	총무-일반-005 (610-RUFU-61747)	5급 강감○	재택근무	2011.12.3 10:00(출)	*김유○*

< 별지 제5호 서식 >

휴대용 저장매체 라벨



< 외장형 HDD 서식 >



< USB·CD 등 서식 >

가. 同 서식을 만들어 휴대용 저장매체 중앙의 적절한 위치에 부착

나. 첫 번째 줄에는 일반/비밀용(인)란에 분임사이버보안담당관 또는 관리자의 직인을 날인

다. 두 번째 줄에는 휴대용 저장매체 관리번호 표기

라. 세 번째 줄의 '정'란에 관리자, '부'란에 취급자 표기

(USB메모리 및 CD의 경우 생략 가능)

마. 휴대용 저장매체의 크기를 고려하여 서식·글자 크기 조정 가능

< 별지 제5호 서식 예시 >

일반용			(인)
총무과-일반-01			
정	이순○	부	홍길○

비밀용			(인)
총무과-비밀-01			
정	이순○	부	홍길○

일반용	(인)
총무과-일반-01	

Ⅱ급비밀용	(인)
총무과-Ⅱ급-01	

< 별지 제6호 서식 >

휴대용 저장매체 불용처리 확인서

아래와 같이 휴대용 저장매체(종 점) 불용처리 및 휴대용 저장매체 (종 점) 재사용에 대해 확인을 요청함

연번	관리번호 (S/N)	매체형태	사유	불용처리	재사용
1	총무과-일반-01 (E-D900-04-3705B)	USB	고장	물리적 파기	
2	총무과-Ⅲ급-01 (5101-53RA-12567)	CD	고장	물리적 파기	
3	총무과-Ⅱ급-01 (610-RURQ-61750)	USB	용도전환	자성소거	총무과-일반-09
4					
5					
6					
7					
8					
9					
10					

확인일자 : 년 월 일

요 청 자 : 소속·직책 O급 성명 : (인)

확 인 자 : 분임사이버보안담당관 O급 성명 : (인)

【 부록 3 】

정보시스템 저장매체 불용처리지침

제1조(목적) 이 지침은「성평등가족부 사이버보안 업무규정」제56조제4항의 규정에 의하여 정보시스템 저장매체의 불용처리에 관련된 사항을 규정함을 목적으로 한다.

제2조(용어 정의) 이 지침에서 사용하는 용어의 정의는 다음 각 호와 같다.

1. "저장매체"란 자기저장장치·광 저장장치·반도체 저장장치 등 자료기록이 가능한 전자장치를 말한다.
2. "소자(消磁)"란 저장매체에 역자기장을 이용해 매체의 자화값을 "0"으로 만들어 저장자료의 복원이 불가능하게 만드는 것을 말한다.
3. "완전포맷"이라 함은 저장매체 전체의 자료저장 위치에 새로운 자료(0 또는 1)를 중복하여 저장하는 것을 말한다.

제3조(정보시스템 저장자료의 보안조치 책임) 각 기관의 장은 정보시스템을 폐기·양여·교체·반납(이하 "불용처리"라 한다)하거나 외부수리를 위하여 기관 외부로 반출할 경우 저장매체에 보관된 자료의 삭제 등 보안조치에 대한 책임을 진다.

제4조(저장매체 불용처리시 자료삭제) 정보시스템 저장매체를 불용처리시 저장자료를 삭제할 경우는 다음 각 호와 같다.

1. 정보시스템의 사용연한이 경과하여 폐기 또는 양여할 경우
2. 정보시스템의 무상보증 기간 중 저장매체 또는 저장매체를 포함한 정보시스템을 교체할 경우
3. 정보시스템의 임대기간이 만료되어 반납할 경우
4. 정보시스템 고장 수리를 위해 외부 반출 등 해당 기관이 정보시스템 저장매체를 보안통제할 수 없는 환경으로 이동이 필요한 경우

제5조(저장매체 불용시 삭제방법) ① 각 기관의 분임사이버보안담당관은 저장매체 불용처리시 다음 분류에 따른 기준 이상으로 삭제한다.

저장 자료 / 저장 매체	공개 자료	비공개 자료	대외비 자료	비밀 자료
자기테이프 플로피디스크	자체 판단	물리적 파괴	물리적 파괴	물리적 파괴
광디스크 (CD·DVD 등)	자체 판단	물리적 파괴	물리적 파괴	물리적 파괴
반도체메모리 (SSD·USB 등)	포맷 또는 삭제	물리적 파괴	물리적 파괴	물리적 파괴
하드디스크	포맷 또는 삭제	디가우징 또는 완전삭제 S/W	물리적 파괴	물리적 파괴

② 제1항에서 지정된 방법과 다른 방법으로 저장자료를 삭제하고자 할 때에는 사전에 국가정보원장과 협의하여야 한다.

제6조(저장자료 삭제 확인) ① 각 기관의 분임사이버보안담당관은 정보시스템을 불용 처리할 경우 저장자료 삭제여부를 확인하여야 한다.

② 정보시스템에 저장된 자료의 삭제를 외부업체에 의뢰할 때에는 분임사이버보안담당관이 입회하여 삭제 절차·방법 준수여부 등을 확인 감독하여야 한다.

제7조(정보시스템 도입시 보안조치) ① 정보화사업담당관은 정보시스템 도입시 고장수리 등을 위하여 공급업체가 저장매체를 교환·반출해 갈 경우에 대비, 저장자료 삭제방법 등 저장매체 보안조치 방안을 계약서상에 포함하여야 한다.

② 정보시스템을 임차 사용할 때에는 임차기간 만료후 반납시 해당 시스템의 저장자료 삭제방법 등 저장매체 보안조치 방안을 임차계약서상에 포함하여야 한다.

제8조(정보시스템 외부반출시 보안조치) ① 불용처리 등을 위하여 정보시스템을

외부로 반출할 경우 사전 분임사이버보안담당관의 통제를 받아야 하며 분임사이버보안담당관은 그 현황을 기록 유지하여야 한다.

② 각 기관의 장은 저장매체의 고장수리·자료복구 등을 위해 외부에 의뢰할 경우 저장매체에 보관된 자료의 유출 방지를 위하여 분임사이버보안담당관 입회, 수리·복구 참여자에 대한 보안서약서 집행·교육 등 필요한 보안조치를 하여야 한다.

③ 정보시스템관리자는 정보시스템을 불용처리 할 경우 해당 시스템의 사용기관·부서·사용자 등을 인식할 수 있는 표시를 모두 제거하여야 한다.

제9조(소자장비 등의 적합성 검증) 각 기관의 장은 정보시스템의 저장자료를 삭제하는 장비나 소프트웨어를 도입할 경우「성평등가족부 사이버보안 업무규정」제2장제5절에 따른 보안적합성 검증절차를 이행하여야 한다.

【 부록 4 】

성평등가족부 보안 위규자 처리 기준

구 분	위 규 사 항	처 리 기 준
심 각	1. 정보유출 가. 정보시스템에 대한 해킹 및 해킹시도 나. 정보통신시스템 해킹으로 비밀 유출 2. 정보시스템 보안 가. 정보시스템에 대한 해킹 및 해킹시도 나. 시스템 내 인위적인 악성코드 유포	○ 보안심사위원회를 통한 위규자 및 직속 감독자 징계 ○ 위규자 인사고과(근무성적평정, 포상, 승진, 교육)에 감점 ○ 위규자 대상 특별보안교육 실시 및 재발방지를 위한 조치계획 제출
중 대	1. 정보유출 가. 정보통신시스템 해킹으로 대외비 유출 나. 인터넷망 PC에 비밀 자료를 임의저장·게시·공유·전송 2. 정보시스템 보안 가. 정보시스템 손괴 및 부정사용, 비인가 SW 사용 등 고의적으로 정보시스템 장애 발생 나. 사용자 계정관리 미흡 및 오남용(시스템 불법접근 시도 등) 3. 관리적 보안 가. 업무망 인터넷망 혼용사용 나. 외부 PC를 업무망에 무단 연결 사용 다. 외부전산망을 무단 설치·운용 라. 보안관련 프로그램 강제 삭제	○ 보안심사위원회를 통한 위규자 및 직속 감독자 경징계 - 근무평정 불이익 조치 - 성과연봉 및 성과상여금 심사 시 감점 - 장관표창 및 국외훈련대상자 선발 시 추천 제외 ○ 위규자 및 부서장 사유서/경위서 징구 ○ 위규자 대상 특별보안교육 실시 및 재발방지를 위한 조치계획 제출

구 분	위 규 사 항	처 리 기 준
보 통	1. 정보유출 가. 정보통신시스템 해킹으로 업무자료 유출 나. 인터넷망 PC에 대외비 자료를 임의저장·게시·공유·전송(웹하드·P2P 등 인터넷 자료공유사이트를 활용하여 업무자료 수발신) 2. 정보시스템 보안 가. 해킹사고 인지 후 미신고 나. 보안시스템을 무력화·우회·편법 사용할 목적으로 관련기법을 전파 또는 공유 다. 비인가 서버구축 및 서비스(홈페이지 등) 운용 3. 관리적 보안 가. 상용메일 무단 사용 나. 비인가 정보통신시스템, 보조기억매체 무단 반입·사용 다. 과실에 의해 악성코드가 감염되었으나 피해 심각(중요자료 대량 유출 등) 라. 기관 정보통신기기 임의 반출 마. 사이버공격 대응훈련 시 보안 위규자 (모의 해킹메일 열람 후 미신고자 등)	○ 위규자 벌당직 ○ 위규자 사유서/경위서 징구, 부서장 통보 ○ 위규자 대상 재발방지를 위한 해당 부서 조치계획 제출
경 미	1. 정보유출 가. 인터넷망 PC에 업무자료를 임의저장·게시·공유·전송 2. 정보시스템 보안 가. 해킹 및 악성코드에 감염된 정보통신시스템 훼손 등 정당한 침해사고 조사행위 방해 나. 외부업체 직원의 전산망 임의 접속, 자료 열람,악성코드 유포 등을 초래한 업무담당자 3. 관리적 보안 가. PC를 켜 놓거나 보조기억 매체(CD, USB 등)를 서랍·책상 위 등에 방치한 채 퇴근 놓고 퇴근 나. PC 비밀번호를 모니터옆 등 외부에 노출 다. 카카오톡 등 비인가 SW 무단 사용 라. 필수 보안프로그램(안티 바이러스, USB 통제 프로그램 등) 미설치 및 우회 마. 사이버공격 대응훈련 시 보안 위규자 (모의 해킹메일 열람자 등) 바. 해커가 인지한 이메일 주소 변경사용 권고 후에도 지속 사용 사. 과실에 의해 악성코드를 감염시켰을 때 아. 공직 기강 및 품위 훼손을 야기하는 등 업무와 무관한 자료 또는 소프트웨어 게시	○ 위규자 서면·구두 경고 등 문책 ○ 위규자 사유서 / 경위서 징구 ○ 자체 보안 교육

【 부록 5 】

정보화사업 보안성검토 처리기준

[보안성 검토 대상 정보화사업 구분]

국가정보원 보안성검토 대상 정보화사업

1. 국가 망 보안체계(N2SF) 정보서비스 모델 구축을 비롯한 N2SF 적용 사업
2. 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 적용하는 정보통신망 또는 정보시스템 구축
3. 외교·국방 등 국가안보상 중요한 정보통신망 또는 정보시스템 구축
4. 100만명 이상의 개인에 대한「개인정보 보호법」상 민감정보 또는 고유식별정보를 처리하는 정보시스템 구축
5. 주요정보통신기반시설로 지정이 필요한 정보통신기반시설 구축
6. 공항·항만·전력·가스·운송설비 등을 중앙에서 감시·제어하기 위한 제어시스템 도입
7. 재난관리·국민안전·치안유지·비상사태 대비 등 국가위기 관리와 관련한 정보통신망 또는 정보시스템 구축
8. 국가정보통신망 등 여러 기관이 공동으로 활용하기 위한 정보통신망 또는 정보시스템 구축
9. 행정정보, 국가지리, 환경정보 등 국가 차원의 주요 데이터베이스 구축
10. 정상회의, 국제회의 등 국제행사를 위한 정보통신망 또는 정보시스템 구축
11. <삭제>
12. <삭제>
13. 통합데이터센터·보안관제센터 구축

14. 제39조제1항제1호에 따른 무선랜의 구축 또는 제40조제1항에 따른 이동통신망·위성통신망(LTE, 5G, 6G 등)의 구축 및 이용
15. 원격근무시스템 구축
16.「전자정부법 제54조의2」및「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」제20조에 따라 클라우드컴퓨팅서비스제공자의 클라우드컴퓨팅서비스를 이용하는 사업
17. 남북 회담 및 협력사업 등을 위한 북한지역 내 정보통신망 또는 정보시스템 구축
18. 외국에 개설하는 사무소 운영을 위한 정보통신망 또는 정보시스템 구축
19. 첨단 정보통신기술을 활용하는 정보화사업으로서 국가정보원장이 해당 기술에 대하여 안전성 확인이 필요하다고 지정하는 사업
20. 다른 기관의 정보통신망 또는 정보시스템과 연동하여 정보의 소통 또는 서비스를 제공하는 정보시스템 구축
21. 대규모 백업·재해복구센터 구축
22. 제47조제4항에 따른 국가 재난 또는 위기 상황 등에서의 온라인 유지보수
23. 인공지능을 활용하는 정보통신망 또는 정보시스템 구축

성평등가족부 보안성검토 대상 정보화사업

1. 국가정보원장으로부터 보안성 검토를 위임받은 사업
2. 홈페이지 및 웹메일 등 웹기반 정보시스템 구축(1억 이상)
3. 인터넷전화시스템 구축
4. <삭제>
5. 제2조제6호에 따른 공개등급 도메인(제39조제1항제2호 또는 제3호에 따른 중계기 형태를 포함한다)의 구축
6. <삭제>
7. <삭제>
8. 주요정보통신기반시설 취약점 분석·평가, 사이버보안컨설팅 등 용역사업

산하기관 보안성검토 대상 정보화사업

1. <삭제>
2. 홈페이지 및 웹메일 등 웹기반 정보시스템 구축(1억 미만)
3. 제41조제1항에 따른 영상회의시스템 구축
4. 제72조제3항에 따른 영상정보처리기기의 구축
5. 백업시스템 구축
6. 대민(對民) 콜센터시스템 구축
7. 기타 해당 기관의 장이 필요하다고 판단하는 정보통신망 또는 정보시스템 구축

보안성검토 생략가능 정보화사업

1. 보안성 검토 대상 정보화사업에 해당하지 아니하는 단순 장비·물품 도입
2. 제14조에 따른 보안성 검토를 거쳐 완료한 정보화사업에 대하여 정보통신망 구성을 변경하지 아니하는 범위(단일 회선의 이중화 포함) 내에서 다음 각 목의 사항을 포함한 후속운영·유지보수·컨설팅
   가. 서버·스토리지·네트워크장비 등 장비 노후화로 인한 단순 장비 교체
   나. 전화기·무전기·CCTV 등 통신·영상기기의 노후화로 인한 단순 장비 교체
   다. 기존 운용하던 정보보호시스템을 동일한 보안기능을 보유한 다른 정보보호시스템으로 교체
   라. 사업자 변경, 임대 기한의 종료 등 단순 후속 운영을 위한 절차
3. 다년도에 걸쳐 계속되는 사업으로써 사업 착수 당시 보안성검토를 완료한 후 사업 내용의 변동 없이 계속 추진하는 운영·유지사업
4. PC·프린터 및 상용 소프트웨어 등 단순 제품 구매·교체·사용권한(라이선스) 기간 연장 또는 사용자수 증감